

Credits (CFU): 6

Semester: 2st Semester

Lecture Notes

- 01_INTRODUZIONE_ORDINAMENTO_FONTI | *Date: 2026-02-09*
 - 02_AI-ACT-SOGGETTIVITA-GIURIDICA | *Date: 2026-02-11*
 - 03_AI-ACT-DIRITTO-AUTORE | *Date: 2026-02-16*
 - 04_DATA-PROTECTION-DIRITTI-FONDI | *Date: 2026-02-18*
 - 05_CAPACITA-AGIRE-GENITORI-MINORI | *Date: 2026-02-23*
 - 06_Data_protection | *Date: 2026-02-25*
 - 07_Fondamenti_Cybersicurezza | *Date: 2026-03-02*
 - 08_Successione | *Date: 2026-03-04*
 - 09_Responsabilità_Piattaforme | *Date: 2026-03-09*
 - 10_Responsabilita_Civile | *Date: 2026-03-16*
 - 11_Guerra_Ibrida | *Date: 2026-03-18*
 - 12_Contratti_BlockChain | *Date: 2026-03-23*
 - A1_Data_Bias
-

Ordinamento Giuridico e Gerarchia delle Fonti

I. Teoria Generale

L'Ordinamento e la Norma Giuridica

L'**Ordinamento Giuridico** è definito come un sistema intrinsecamente flessibile, capace di adattarsi, ma vincolato al rispetto assoluto della **Costituzione**.

La **Norma Giuridica**, è una regola di condotta obbligatoria imposte dallo stato per la convivenza sociale (***inosservanza comporta a sanzione***), esse deve possedere il requisito della costituzionalità (deve "stare sotto" la Costituzione). Il contenuto della norma si identifica con il precetto legale stesso.

Principio di Abrogazione

Nel caso in cui due leggi si sovrappongano si controlla l'autorità di ciascuna:

- **Abrogazione** = se due leggi di eguale autorità sono in conflitto, la più recente abroga la precedente (se le due sono incompatibili)
- **Subordinazione** = se due leggi di autorità diversa sono in conflitto, la più autorevole viene applicata al posto della meno autorevole se le due sono incompatibili

Nell'ordinamento italiano le norme scritte sono di diritto positivo (*positum* = posto), cioè poste da un'autorità sovrana in un preciso contesto storico e geografico. Si distingue dal diritto naturale perché è creato dagli esseri umani e reso obbligatorio attraverso sanzioni formali.

Parlamento e promulgazione leggi

L'autorità nell'ambito della **promulgazione delle leggi** è il **Parlamento** (potere conferito dalla *Costituzione*). Per **approvare** una legge, **entrambe** le camere devono approvarla .

Se questo **non avviene per 2 volte** si va al **referendum** (*confermativo*). Viceversa, se la legge viene approvata, questa viene mandata al **Presidente della repubblica** che ha la possibilità di (diritto di voto contro le leggi ritenute anticonstituzionali) rimandare alle camere una legge ritenuta non conforme alle norme presenti nella costituzione. Se le camere rimandano al Presidente della Repubblica la stessa legge senza modifiche, questo è costretto a promulgarla (firmarla).

Esistono altri 2 tipi di referendum che ai quali il popolo può essere chiamato a votare:

- In caso di un **cambio** della **costituzione**
- Per **abrogare** una **legge** in vigore (per fare ciò è necessario seguire un iter che include raggiungere un certo numero di persone che firmino per l'abrogazione)

II. Gerarchia delle Fonti

La Costituzione

La Costituzione rappresenta il vertice e la **fonte suprema** dell'ordinamento *italiano*. Una sua caratteristica fondamentale è la **rigidità**, che la distingue dalle costituzioni flessibili.

Costituzione Rigida vs Flessibile

A differenza dello Statuto Albertino, che era flessibile (modificabile con legge ordinaria), la Costituzione italiana è rigida e non può essere modificata da leggi ordinarie.

Esiste un meccanismo di **Controllo di Costituzionalità** per garantire che ogni legge rispetti la Carta fondamentale.

Il Garante

Il Presidente della Repubblica agisce come garante della Costituzione.

Per modificare la Costituzione è necessario un procedimento specifico di **Revisione Costituzionale**, che richiede un "Aggravamento Costituzionale" secondo quanto previsto dall'art. 138 Cost.

Ordinamento e Leggi Nazionali

Il **Parlamento** è l'organo costituzionale centrale deputato alla **produzione legislativa**. Oltre alla legge ordinaria, esistono gli **Atti aventi forza di legge**, equiparati alla legge ma emanati dal Governo:

- **Decreto Legislativo (d.lgs):** Atto adottato dal Governo sulla base di una "Legge Delega" fornita preventivamente dal Parlamento, che definisce principi e criteri direttivi.
- **Decreto Legge (d.l):** Atto straordinario di necessità e urgenza adottato dal Governo (immediatamente efficaci). A meno che di promulgazioni deve essere convertito in legge dal Parlamento (entro 60 giorni) per non perdere efficacia sin dall'inizio (*ex tunc*) (decade)

Abbiamo successivamente i **regolamenti**, norme attuative che dettano disposizioni dettagliate di **applicazioni di legge** (vengono dal presidente della repubblica o dal Primo ministro).

A livello *locale*, le Regioni emanano le **Leggi Regionali (L.R.)**, che costituiscono norme di rango primario limitatamente alla competenza territoriale e materiale.

Unione Europea

L'Italia aderisce formalmente all'Unione Europea tramite i trattati (Maastricht, TUE e TFUE). Ciò permette il libero circolo delle merci e delle persone, nello specifico con quello di Maastricht viene prevista la protezione di ambiti collaterali al mercato (diritto di viaggio, validità di titolo, ecc...) Invece con la **Carta di Nizza**, definiamo i regolamenti e direttive che sanciscono norme efficaci per tutti i cittadini e gli stati dell'UE.

In questo modo le fonti del diritto dell'Unione si distinguono principalmente in:

- **Regolamento UE:** È un atto di portata generale, obbligatorio in tutti i suoi elementi e **direttamente applicabile** in ciascuno degli Stati membri. Non necessita di alcun atto di recezione interna per essere efficace.
- **Direttiva UE:** Non è direttamente applicabile (salvo eccezioni per le *self-executing*). Essa vincola lo Stato membro al raggiungimento di un risultato (obiettivi e temi), lasciando agli organi nazionali la competenza in merito alla forma e ai mezzi. Richiede quindi norme interne di recepimento entro un termine stabilito.

Ogni traduzione degli atti pubblicata nella Gazzetta Ufficiale dell'Unione Europea, nelle 27 lingue degli Stati membri, ha piena validità legale.

Al Act e Soggettività Giuridica

Fondamenti: Il Codice Civile e i Soggetti di Diritto

Il diritto si basa su norme che regolano i rapporti tra soggetti. Spesso il legislatore utilizza tecniche specifiche per aggiornare le norme senza alterarne la numerazione, come l'uso di articoli "bis" (incisi che aggiornano il testo). Il Codice Civile italiano è un *regio decreto*, in quanto deriva da quello precedente e ha la stessa forza normativa di **un** decreto e non perde di efficacia nel tempo se viene modificato.

E' diviso in 6 libri.

Struttura delle norme

Gli articoli di legge si dividono in "Comma". Tuttavia, nelle fonti europee si utilizza il termine "paragrafo". Il terzo comma dell'Art. 1 è stato abrogato con l'avvento della **Repubblica**.

Libro 1 Codice Civile

Il **libro 1**, intitolato "**Delle persone e della famiglia**", introduce concetti *fondamentali*.

Il termine "**persona**" nel diritto include sia le persone fisiche che le persone giuridiche (soggetto di diritto). Il **soggetto di diritto** acquisisce la capacità giuridica alla **nascita**

Origine

Questo concetto deriva storicamente dal teatro greco e dal diritto romano, dove la "persona" era la maschera utilizzata per rappresentare un personaggio.

Oggi, l'ordinamento considera "persona" chiunque sia riconosciuto come tale dalla legge, identificandolo generalmente con l'essere umano (non importa chi c'è dietro la maschera).

Non tutto ciò che accade costituisce un obbligo giuridico; è fondamentale individuare i **soggetti di diritto**, ovvero coloro a cui può essere imputata una qualsiasi situazione giuridica. Un esempio è il **diritto alla vita**, che è un diritto soggettivo pieno: la sua tutela non è solo di riflesso, ma costituisce un **obbligo** verso tutti a rispettarlo.

Diritto alla salute

La legge riconosce il diritto inviolabile alla salute (rif. Art. 32 Costituzione e Art. 1 Codice Civile).

Esistono **situazioni giuridiche passive** (come il debito) e **attive** (come il diritto di credito). Nei rapporti specifici, come quelli di lavoro, i soggetti sono determinati. Al contrario, gli animali **non** sono considerati soggetti giuridici ma **oggetti di diritto** (es. il cane è trattato come un bene), sebbene vi siano crescenti tutele.

L'Intelligenza Artificiale come Oggetto di Diritto

L'ordinamento italiano ed europeo classifica l'Intelligenza Artificiale (IA) come uno **strumento**, non come un soggetto. Tuttavia, l'utilizzo dell'IA può causare danni, sollevando questioni complesse sulla responsabilità civile, specialmente quando sono **coinvolti terzi**.

Definizione di "Terzo"

In ambito giuridico, per "terzo" si intende un soggetto estraneo al rapporto giuridico di base (es. contratto) tra le parti principali.

Si considerino i seguenti esempi di danno:

1. Una vettura a guida autonoma che investe un passante (soggetto terzo) o danneggia l'utilizzatore.
2. Un braccio robotico che commette un errore durante un'operazione chirurgica (presupponendo il consenso informato del paziente).

In questi casi, il terzo danneggiato a chi deve chiedere il risarcimento? Al chirurgo? Allo sviluppatore software?

Il problema risiede nella natura dell'IA: dato un *certo input*, l'*output* **non** è sempre pre-programmato in modo **deterministico**. L'IA possiede una caratteristica di parziale autonomia. L'output generato dall'IA può rientrare nella sua "autonomia", rendendo difficile tracciare la responsabilità. Il legislatore ha dovuto trovare un compromesso tra i valori dell'UE (protezione degli umani) e le esigenze delle aziende (sviluppo tecnologico). Difatto l'approccio scelto con l'AI Act è **antropocentrico**: l'uomo deve rimanere al centro.

L'AI ha la Capacità di agire ?

Non per adesso. L'Art. 2 del Codice Civile stabilisce che la capacità di agire (la capacità di porre in essere atti giuridici validi) si acquisisce con la maggiore età, ovvero a 18 anni, momento in cui si diventa giuridicamente autonomi.

Regolamento (UE) 2024/1689: L'AI Act

L'AI Act è il Regolamento (UE) 2024/1689 del Parlamento Europeo e del Consiglio. La nomenclatura indica l'anno (2024) e il numero progressivo. Essendo un Regolamento, ha portata generale ed è direttamente applicabile in tutti gli Stati membri.

Gerarchia delle Fonti

I regolamenti UE sono sovraordinati alle leggi nazionali. Se una legge statale è in contrasto con il regolamento, prevale la norma europea.

Il testo è stato approvato dal Parlamento (titolare del potere legislativo, rappresentante dei cittadini) e dal Consiglio (formato dai rappresentanti degli Stati europei, espressione delle politiche nazionali). Nelle fasi finali è stato aggiunto un inciso specifico per regolare i chatbot (IA generativa).

L'AI Act mira a regolare il **mercato unico europeo** dell'intelligenza artificiale, ma con una forte attenzione alla protezione dei diritti fondamentali, inclusa la protezione dei dati personali.

Trattati UE

Nei trattati fondamentali dell'UE viene specificato che la **protezione dei dati personali** rientra tra i **diritti dell'uomo**.

Questo approccio distingue l'Europa da modelli come quello cinese o statunitense, dove la regolamentazione è meno stringente sui diritti. Gli USA, ad esempio, si sono ritirati da alcuni trattati internazionali sull'IA e premono per un allentamento delle norme.

L'AI Act rappresenta il primo testo organico al mondo sull'argomento, nato anche per evitare la frammentazione causata da singoli stati sovrani che avevano iniziato a legiferare autonomamente.

Definizione e Caratteristiche Tecniche dei Sistemi IA

Il Regolamento fornisce definizioni precise, in particolare nei "Considerando" (le parti non precettive che spiegano gli obiettivi, come il *Considerando 12*) e nell'articolato.

Art. 3 - Definizione di Sistema di IA:

Un sistema di IA è un sistema automatizzato progettato per funzionare con livelli di autonomia variabili che può presentare adattabilità dopo la diffusione. Per obiettivi espliciti o impliciti, il sistema deduce dall'input che riceve come generare output (previsioni, contenuti, raccomandazioni, decisioni) che possono influenzare ambienti fisici o virtuali.

Una caratteristica fondamentale è la **capacità inferenziale**: il processo di ricavare modelli o algoritmi da dati/input per produrre risultati.

📘 Test di Turing

Ad oggi, l'IA non supera ancora pienamente il "Turing Imitation Game". Si riterranno le macchine veramente intelligenti quando potranno svolgere compiti che richiedono un'intelligenza umana generale indistinguibile.

📘 La Stanza Cinese (John Searle)

Secondo il filosofo John Searle, una macchina può superare un test di output (comportarsi come se capisse), ma senza avere alcuna reale comprensione semantica di ciò che sta elaborando (esperimento mentale della Stanza Cinese).

Dal punto di vista tecnico e legale, è necessario poter percorrere a ritroso le decisioni prese dall'IA (spiegabilità), anche se l'IA interpreta il linguaggio umano ed è molto adattabile. Deve essere sempre garantita la sorveglianza umana (*human in the loop*).

Il ragionamento dell'IA differisce da quello tradizionale:

- **Ragionamento classico:** Basato su regole deduttive.
- **Ragionamento IA (Machine Learning):** Basato sull'inferenza e sull'apprendimento automatico (dal particolare al generale).

📘 Abduzione

Nella logica, questo tipo di ragionamento inferenziale probabilistico è spesso associato al concetto di "abduzione" (generare l'ipotesi più probabile data un'osservazione).

AI Act, Diritto d'Autore e Gestione del Rischio

Opacità dell'AI e Ruolo dei Dati

Una delle caratteristiche fondamentali dei sistemi di Intelligenza Artificiale attuali è l'opacità, spesso definita come "**Blackbox**". Nemmeno gli sviluppatori sono in grado di spiegare il *perché* di un determinato output, ma possono solo illustrare il "percorso" logico compiuto. Sostanzialmente, si tratta di una lettura statistica basata sui dati di addestramento.

I dati sono cruciali durante il training e influenzano direttamente l'output. Un sistema addestrato su dati "vecchi" o contenenti pregiudizi (*bias*) produrrà risultati alterati. Esistono dati "vecchi" che sono caduti nel pubblico dominio.

Liber Liber e Pubblico Dominio

Progetti come **Liber Liber** raccolgono e rendono disponibili libri e opere ormai in pubblico dominio, ovvero libere da diritti patrimoniali e accessibili a tutti.

Diritto d'Autore: Fondamenti e Durata

Il pubblico dominio subentra quando il diritto d'autore decade. Il diritto d'autore è un **diritto fondamentale** e nasce nel momento in cui un autore crea un'opera creativa. Nel 1983 ci furono aggiornamenti normativi per includere **fotografia** e **cinematografia**, superando i dubbi iniziali sul fatto che fosse la macchina, e non l'artista, a **produrre** l'opera.

La discriminante è la **creatività**: una mostra o un'immagine sono protette se esprimono una visione creativa. Quando manca la creatività, come nel caso di alcune **banche dati**, subentra una protezione diversa (diritto *sui generis*) di durata limitata (15 anni), che tutela l'investimento piuttosto che l'originalità. Negli anni, anche il software è stato incluso tra le opere protette.

Il diritto d'autore si divide in:

1. **Diritto Morale**: Il diritto *inalienabile* di essere riconosciuti (ordinamento riconosce il diritto) come autori dell'opera (espressione della personalità dell'autore) in cui l'autore esprime se stesso.
2. **Diritto Patrimoniale d'autore**: Il diritto di sfruttare economicamente l'opera (es. farsi pagare per l'utilizzo).

Il diritto patrimoniale è disponibile e rinunciabile. Questo è alla base del software **Open Source** (codice aperto, modificabile, sviluppo comunitario) e delle licenze **Creative Commons**

Plagio

Il plagio è la violazione del diritto d'autore tramite l'appropriazione, totale o parziale, di un'opera altrui spacciandola per propria. È punito penalmente. In ambito accademico (tesi), spesso si utilizzano soglie di tolleranza (es. 25%), e i controlli odierni includono anche il testo generato da IA.

Durata e Differenze Internazionali

- **Italia/Europa**: Il pubblico dominio si ottiene **70 anni dopo la morte dell'autore**. Cessa il diritto patrimoniale (non si può più guadagnare dall'esclusiva), ma permane il diritto morale.
- **USA**: Vigeva il **Copyright** (diritto di copia), focalizzato più sull'aspetto economico che morale. La durata è diversa: 75 anni, estesi a 95 anni con il *Mickey Mouse Act* (opere dal 1922 al 1978). Per acquistarlo c'è bisogno di un accertamento dell'originalità.

SIAE e Licenze

In Italia, l'originalità si può depositare alla SIAE. La SIAE controlla l'utilizzo delle licenze e riscuote i diritti per conto degli autori. Al giorno d'oggi tecnologie come la **Blockchain** possono oggi essere usate per provare l'originalità e la data certa di un contenuto.

Il **marchio** (es. logo Disney) è diverso dal diritto d'autore: è un **titolo di proprietà industriale** che copre un simbolo/prodotto nel mercato contro i falsi e, se rinnovato (pagato), non scade mai (invece Topolino può essere usato nella versione originale).

Marchio vs Diritto d'Autore

Il marchio tutela i segni distintivi di un'impresa (brand, logo) per evitare confusione nel consumatore e contraffazione. A differenza del diritto d'autore che ha una scadenza naturale, il marchio può essere rinnovato all'infinito.

Bias nei Dati e Applicazioni Mediche

Tornando all'AI, l'uso di dati di addestramento pubblici o storici può introdurre pregiudizi (es. bias razziali). Anche in medicina, algoritmi addestrati su vecchi casi (es. medicina nucleare) possono identificare nuove patologie permettendo diagnosi anticipate. Tuttavia, l'AI soffre del problema dei **falsi positivi/negativi**, specialmente su patologie rare.

L'AI può suggerire *come* è arrivata a un risultato, ma non può spiegarne il *perché* profondo. Il **verdetto finale** spetta sempre all'**utilizzatore umano** (es. il radiologo).

Bias nei dati di addestramento

I bias sono distorsioni sistematiche nei dati usati per il training (es. sovrarappresentazione di una etnia o genere). Se i dati in ingresso sono viziati, l'algoritmo replicherà e amplificherà tali pregiudizi nelle sue decisioni (fenomeno *Garbage In, Garbage Out*).

AI Act: Approccio basato sul Rischio

L'AI Act adotta un approccio basato sulla sicurezza del prodotto (scelta di campo: il prodotto deve essere plasmato per evitare usi nocivi). Non vieta l'AI in sé, ma **classifica** i sistemi in base al rischio per i diritti fondamentali.

Riferimento ai Trattati UE

La classificazione dei rischi si fonda sui valori sanciti dalla Carta dei diritti fondamentali dell'Unione europea (CARTA DI NIZZA) e dai trattati istitutivi (TUE, TFUE), discussi nella lezione precedente.

Definizione e Formula del Rischio

L'Art. 3 num. 2 definisce il rischio come la combinazione della probabilità del verificarsi di un danno e la gravità del danno stesso.

$$R = P \times D$$

Dove R è il Rischio, P è la Probabilità e D è il Danno.

Tale linea guida non si applica alla ricerca.

La Piramide del Rischio

L'AI Act struttura i sistemi in una piramide.

1. Pratiche Vietate (Rischio Inaccettabile)

Sono pratiche bandite dal mercato UE (ma permesse per scopi di ricerca pura). Includono sistemi che manipolano il comportamento o sfruttano vulnerabilità (Art. 5).

Esempio: **Social Credit Score**.

A differenza del *Credit Score* bancario, il Social Scoring (nato in Cina) valuta la persona nella sua interezza (comportamenti, caratteristiche fisiche), mettendo a rischio diritti e libertà.

Contesto cinese

In Cina, il sistema di credito sociale è legato a meccanismi di controllo statale pervasivi, facilitati anche da problematiche storiche di registrazione all'anagrafe e controllo demografico.

Dettaglio Articolo 5 (Pratiche Vietate)

L'Articolo 5 elenca tassativamente le pratiche proibite perché contrarie ai valori dell'Unione, come la manipolazione subliminale, lo sfruttamento di gruppi vulnerabili (bambini, disabili) e la valutazione sociale da parte delle autorità pubbliche. Queste pratiche sono vietate dal 2025.

2. Sistemi ad Alto Rischio

Sono sistemi che possono avere un impatto negativo sulla sicurezza o sui diritti fondamentali (**Art. 6**). Sono considerati tali se integrati in prodotti di sicurezza o usati in settori sensibili

(biometria, polizia, istruzione, lavoro).

Esempio: Algoritmo spagnolo (*VioGén*) per la violenza di genere, che suggeriva ai poliziotti il fattore di rischio di recidiva.

Esempio: Identificazione biometrica remota "live" in spazi pubblici. Oggetto di forte dibattito tra Garante Privacy EU ed Europol. È tendenzialmente vietata salvo eccezioni gravissime (terrorismo, ricerca dispersi), poiché configura una sorveglianza di massa.

Pacchetto Omnibus e Tempistiche

Esistono pressioni (es. USA) che influenzano l'entrata in vigore di alcune norme. Il riferimento al "Pacchetto Omnibus" suggerisce slittamenti o modifiche nelle date di applicazione per specifici obblighi (es. Art 6 par 2 potrebbe slittare al 2027/2028).

Allegato 1

L'Allegato 1 dell'AI Act contiene l'elenco delle normative di armonizzazione dell'UE. Se un sistema AI è un componente di sicurezza di un prodotto coperto da queste norme (es. giocattoli, ascensori, auto), è automaticamente ad alto rischio.

Sorveglianza Umana (Human in the loop)

Per i sistemi ad alto rischio è obbligatoria la sorveglianza umana. L'uomo deve poter intervenire, interpretare l'output e, se necessario, ignorare o spegnere il sistema (come nel caso dell'algoritmo di polizia).

Articolo 3, comma b

Riferimento alle definizioni aggiornate dei fornitori e dei deployer (utilizzatori) dei sistemi di IA, essenziali per stabilire le responsabilità nella catena del valore.

3. AI per Finalità Generali (GPAI)

L'AI Act è stato aggiornato per includere i modelli "General Purpose" (Art. 3, def. 63). Questi modelli, addestrati su grandi quantità di dati (autosupervisione), possono svolgere un'ampia gamma di compiti e integrarsi in sistemi a valle.

Se possiedono capacità di impatto elevato, presentano un **Rischio Sistemico** (def. 65): possono causare incidenti su larga scala, influenzare la salute pubblica o propagare effetti negativi lungo la catena del valore.

Soglia dei FLOPs

Per determinare se un modello GPAI ha un "rischio sistemico", la Commissione usa criteri tecnici come la potenza di calcolo utilizzata per l'addestramento, misurata in FLOPs (Floating Point Operations). Superata una certa soglia, il rischio è presunto.

AI e Diritto d'Autore in Italia (L.633/1941)

La normativa italiana specifica che il diritto d'autore è riservato agli esseri umani. Le opere create con l'ausilio di strumenti AI possono essere protette solo se si dimostra un apporto creativo umano significativo (il lavoro intellettuale deve essere documentato).

Text and Data Mining (Art. 70-ter)

L'articolo recepisce la direttiva sul diritto d'autore nel mercato unico digitale. È consentita l'estrazione di testo e dati da opere legittimamente accessibili per l'addestramento dell'AI.

- **Opt-out:** I titolari dei diritti possono riservare l'uso delle loro opere (es. tramite file `robots.txt` nei siti web, come fatto dal *Corriere della Sera*).
- **Consenso:** Se non è specificato il divieto ("non espressamente riservato"), l'estrazione è consentita.

Vi sono dibattiti tecnici sulla natura dell'output: alcuni sostengono che i sistemi vettoriali frammentino i dati a tal punto da non violare il diritto d'autore nell'output; altri sostengono che se il risultato non è frutto dell'intelletto umano, non è proteggibile.

Reato di Deepfake

Il "Deepfake" non è solo una tecnologia ma può configurare reati specifici (es. sostituzione di persona, diffamazione, pornografia non consensuale). La normativa sta evolvendo per punire l'uso malevolo di manipolazioni audio/video realistiche.

Data Protection e Diritti Fondamentali

Capacità Giuridica e Diritti Fondamentali

Alla nascita si acquisisce la **capacità giuridica**, ovvero l'idoneità ad essere titolari di diritti e doveri, diventando così soggetti di diritto. Quando il Codice Civile fu approvato, non tutti godevano degli stessi diritti; la svolta avvenne con la Costituzione. L'**Articolo 2** stabilisce che la Repubblica "*riconosce i diritti fondamentali della persona*". Essendo nata dopo il referendum del

1946, la Repubblica si limita a riconoscere tali diritti in quanto spettano a tutti gli esseri umani da sempre, pur variando da ordinamento a ordinamento.

❗ **Lo Statuto Albertino concedeva alcuni diritti: poiché si trattava di una concessione dall'alto, questi diritti erano revocabili.**

Caratteristiche dei Diritti Fondamentali

I diritti fondamentali costituiscono la base del nostro ordinamento.

Essi hanno due caratteristiche specifiche:

- Sono **Fondamentali**, in quanto fondamento che spettano a tutti gli esseri umani (indipendentemente dall'origine)
- Sono **Inalienabili** e **indisponibili**, un atto dispositivo in cui il titolare si spoglia in maniera definitiva del proprio diritto non è ammissibile, al contrario di un contratto che regola rapporti patrimoniali.

❗ Nota

Un diritto è indisponibile anche per la persona cui il diritto spetta (disporre di un diritto del genere significa disporre di un diritto dell'Uomo). Per esempio non siamo del tutto proprietari nemmeno della nostra stessa vita (**integrità fisica**).

Esempio - Diritto all'integrità fisica

E' possibile donare un organo (solo organi doppi e a titolo di donazione), e il nostro ordinamento lo permette esclusivamente a patto che venga rispettata l'integrità vitale della persona (senza causare la morte). L'indisponibilità si applica anche post-mortem per l'espianto.

Esempio - Diritto all'immagine

è indisponibile: spetta a chi viene fotografato e la diffusione può avvenire solo con il suo consenso. Se diffusa senza consenso, il diritto è violato, a meno che la pubblicazione non sia esplicitamente legittimata dalla legge. L'ordinamento impone l'indisponibilità anche contro la volontà di chi esprime il consenso, per tutelare la dignità umana; ad esempio, un individuo non può decidere di diventare schiavo, rinunciare alla propria vita (tematiche di fine vita) o subire pratiche lesive della dignità (es. il lancio del nano in Francia).

Origini del Diritto alla Privacy

Negli Stati Uniti, il diritto alla privacy è inteso come il diritto di essere lasciati in pace all'interno della propria sfera privata ("right to be let alone"). L'origine dottrinale di questo diritto risale a un articolo del 1890 della Harvard Law Review ("The Right to Privacy"), nato all'interno del sistema di *equity*.

Il diritto alla riservatezza si configura come un diritto "negativo": è il diritto di negare ad altri

l'accesso ai propri affari personali.

Questo concetto nasce originariamente come baluardo e difesa del cittadino contro la stampa, ma anche contro le ingerenze dello Stato.

Un concetto simile è quello di "segreto". Il **segreto professionale**, ad esempio, copre le informazioni acquisite in ragione delle funzioni e del proprio ambito lavorativo. Un altro esempio parallelo è il segreto di Stato. Su un piano normativo affine si inserisce il reato informatico di accesso abusivo a un sistema: si concretizza quando si entra in un sistema superando i limiti del consenso accordato e violando le misure di sicurezza.

Evoluzione Normativa Europea

La **Carta di Nizza** (Carta dei diritti fondamentali dell'Unione Europea, datata 18.12.2000. Successivamente riadattata nel 12.12.2007), recepita dal **Trattato di Lisbona** e ratificata in Italia nel 2009, rappresenta uno snodo fondamentale. Il documento si apre sancendo i diritti legati all'integrità della persona.

Alcuni degli articoli della Carta di nizza

L'Articolo 7 tutela il rispetto della vita privata e della vita familiare.

L'Articolo 8 introduce i tre concetti di segreto, riservatezza e protezione, che in ambito giuridico rimangono tre concetti differenti. In Europa, il concetto di privacy nella sua forma contemporanea si sviluppa nel secondo dopoguerra.

Anche l'*anonimato* è considerato un **diritto entro certi limiti**, sebbene in ambito informatico sia spesso percepito con accezione negativa. Non esiste una definizione giuridica di "dark web", ma esistono norme specifiche che regolano la pubblicazione e la gestione delle informazioni sulla rete.

Trattamento dei Dati Personali e GDPR

Il **diritto all'auto-informazione** (o autodeterminazione informativa) è la facoltà di decidere cosa far conoscere di sé agli altri e cosa ricevere dall'esterno (es. blocco spam).

Qualsiasi operazione compiuta con i dati prende il nome di "trattamento". Un trattamento di dati personali si può attuare solo se sussistono i **presupposti di legittimità** previsti dall'**Articolo 6 del Regolamento Privacy** (GDPR 679/2016). Pur essendoci i presupposti legali, devono sempre essere rispettate le modalità d'uso conformi alla norma.

Nota

Da qui la Documentazione al consenso del trattamento dei dati personali presente su tutti i software/portali web

Il trattamento rappresenta il dominio che l'individuo ha sui propri dati personali; sottrarre tale dominio significa violare un diritto fondamentale. A differenza del concetto tradizionale di

privacy, qui si delinea un diritto attivo sul dominio dei dati.

Articolo 9 GDPR

Disciplina i "dati sensibili" che di base non devono essere trattati: origine razziale, orientamento sessuale, appartenenza politica, dati genetici/sanitari e convinzioni religiose. Si deroga a questo principio solo in casi rigidamente regolamentati di necessità, configurandosi come norma eccezionale.

Norma eccezionale

Essa prevede sempre una stretta interpretazione in sede giuridica.

La Protezione dei Dati nel Regolamento (Art. 5 e Art. 8)

Articolo 8

Secondo l'**Articolo 8** del GDPR, **ogni** individuo ha diritto alla protezione dei dati di carattere personale che lo riguardano. Questi dati devono essere trattati secondo il principio della lealtà, per finalità determinate e in base al consenso della persona interessata, o in virtù di un altro fondamento legittimo previsto dalla legge. Ogni individuo ha il diritto di accedere ai dati raccolti che lo riguardano e di ottenerne la rettifica. Il nostro Codice della Privacy prevede anche illeciti di rilevanza penale in determinati ambiti, che si realizzano quando non vengono rispettati i criteri normativi di trattamento.

Articolo 5

L'Articolo 5 (C39) del GDPR ribadisce i concetti di tutela e definisce i principi cardine per il trattamento dei dati personali:

1. **Liceità, correttezza e trasparenza:** I dati devono essere trattati in modo lecito, corretto e trasparente nei confronti dell'interessato.
2. **Limitazione della finalità:** Raccolti per scopi determinati, espliciti e legittimi. Un trattamento ulteriore per finalità di archiviazione nel pubblico interesse, o per ricerca scientifica/storica o a fini statistici (conformemente all'art. 89) non è considerato incompatibile.
3. **Minimizzazione dei dati:** I dati devono essere adeguati, pertinenti e limitati a quanto necessario rispetto alle finalità.
4. **Esattezza:** Esatti e aggiornati. Vanno adottate le misure ragionevoli per cancellare o rettificare tempestivamente i dati inesatti.
5. **Limitazione della conservazione:** Conservati in una forma che permetta l'identificazione degli interessati per un periodo non superiore al conseguimento delle finalità stesse.

6. **Integrità e riservatezza:** Trattati garantendo un'adeguata sicurezza, comprese adeguate misure tecniche e organizzative per proteggerli da trattamenti illeciti, perdita, distruzione o danni.

Accountability

Il titolare del trattamento è direttamente responsabile per il rispetto di questi principi e deve essere in grado di provarlo (**Responsabilizzazione / Accountability**). I dati personali sono definiti come tutti quei dati riconducibili in modo diretto o indiretto ad una persona fisica identificata o identificabile.

Capacità d'Agire, Responsabilità Genitoriale e Diritti dei Minori

Capacità Giuridica e Capacità d'Agire

La persona fisica acquista la capacità d'agire al compimento del diciottesimo anno di età. Fino a quel momento, pur potendo essere titolare di situazioni giuridiche e diritti (ad esempio, l'eredità o la ricezione di un immobile tramite donazione), il minore non ha la capacità di esercitarli autonomamente in sede legale.

Info

La capacità giuridica, a differenza della capacità d'agire, si acquisisce fin dal momento della nascita.

Amministrazione del Patrimonio (Art. 320 c.c.)

L'articolo 320 del Codice Civile disciplina la rappresentanza legale dei minori. I genitori, o colui che esercita la responsabilità genitoriale in via esclusiva, rappresentano i figli nati e nascituri fino alla maggiore età o all'emancipazione.

Il meccanismo è simile a quello del mandato con **procura**: il genitore firma e "spende il nome", ma gli **effetti giuridici** ricadono interamente **sul minore**.

Per l'amministrazione dei beni si applicano le seguenti regole:

- **Ordinaria Amministrazione:** Gli atti possono essere compiuti disgiuntamente da ciascun genitore.
- **Straordinaria Amministrazione:** Per atti che eccedono l'ordinaria amministrazione (alienare, ipotecare, accettare o rinunciare a eredità, contrarre mutui o locazioni

ultranovennali) è indispensabile l'autorizzazione del **Giudice Tutelare**. Il tribunale competente valuta i parametri di necessità e di "utilità evidente" per il figlio prima di autorizzare, ad esempio, l'accettazione di una donazione o la riscossione di capitali. In caso di conflitto di interessi patrimoniali tra figli soggetti alla stessa responsabilità genitoriale, o tra figli e genitori, il giudice tutelare nomina un curatore speciale per tutelare il minore.

Dalla Potestà alla Responsabilità Genitoriale

Il Codice Civile originario aveva un'impostazione fortemente patrimoniale. Fino alla Riforma del 1975, si parlava di "potestà genitoriale", un sistema in cui il padre godeva di una posizione di autorità e supremazia all'interno della famiglia.

Articolo 29 Costituzione

Con la Riforma del Diritto di Famiglia del 1975 e il richiamo all'Articolo 29 della Costituzione, viene riconosciuta la famiglia naturale fondata sul matrimonio, basata sull'assoluta parità dei coniugi. La "**potestà**", tuttavia, rimaneva definita come un potere attribuito a un soggetto da esercitarsi nell'interesse esclusivo di un altro, mantenendo un'asimmetria formale tra genitore e figlio. Tali poteri erano (e sono) sottoposti a controlli: gli **artt. 330 e 333 del Codice Civile** prevedono la possibilità di decadenza o revoca in caso di condotte pregiudizievoli.

Articolo 30 Costituzione

La svolta avviene con la Riforma della Filiazione del 2012 e l'Articolo 30 della Costituzione: il concetto di potestà viene definitivamente sostituito da quello di **responsabilità genitoriale**. In accordo con la **Convenzione UNICEF sui diritti del fanciullo**, si impone di tenere sempre conto dell'interesse superiore del minore e delle sue personali inclinazioni.

Esempi di casi di interesse superiore del minore

☰ La minore che vuole interrompere la gravidanza (all'insaputa dei genitori o contro l'opinione dei genitori) può rivolgersi ad un giudice che deve valutare il danno (psico-fisica) che il parto potrebbe causare alla minore in questione (articolo 126 del codice civile degli anni '70). Si tratta, in questo caso, di un diritto in quanto è un'interpretazione del diritto fondamentale alla salute psico-fisica. La donna minorenni può ricevere la prescrizione del consultorio per accedere a metodi contraccettivi gratuitamente. Il consultorio deve rispettare il diritto alla riservatezza della donna anche con la famiglia (non può dare questo tipo di informazioni alla famiglia)

☰ Un minore che viene trovato sotto effetto di stupefacenti può decidere di intraprendere un percorso di disintossicazione anche senza interpellare i genitori

☰ Quando ci si iscrive alla scuola superiore è lo studente che può decidere se ricevere o meno l'insegnamento della religione (libertà religiosa).

☰ Se un minore fa un acquisto all'insaputa del tutore, questo può richiedere l'annullamento dell'acquisto e la restituzione della somma versata

Riservatezza, Capacità di Discernimento e Contratti dei Minori

Esistono casi specifici in cui il minore può esercitare diritti fondamentali volti a tutelare il proprio benessere psicofisico e la propria privacy, opponendosi persino ai genitori. L'**Articolo 2** della Costituzione garantisce i diritti inviolabili dell'individuo anche all'interno delle formazioni sociali, famiglia inclusa. La legge protegge la riservatezza del minore limitando l'accesso genitoriale a specifiche informazioni personali e mediche (es. l'uso della pillola anticoncezionale).

Info

Esistono norme specifiche per minorenni che permettono di esercitare diritti contro i genitori: ad esempio, la normativa sull'interruzione volontaria di gravidanza (aborto).

Il principio che sorregge l'Articolo 2 del Codice Civile è la *presunzione* di capacità d'agire a 18 anni. Tuttavia, questo non esclude l'emergere progressivo della **capacità di discernimento** (la capacità di intendere e di volere) prima della maggiore età.

L'Annulabilità dei Contratti Stipulati dal Minore

Nel linguaggio giuridico corretto, i contratti stipulati dal minore non sono soggetti a *rescissione* (che si applica solo in casi di stato di pericolo o bisogno), ma ad **annullabilità** (Art. 1425 c.c.). Poiché il minore non ha la capacità d'agire, i contratti da lui conclusi possono essere annullati su richiesta dei genitori o del minore stesso una volta maggiorenne.

Esistono tuttavia due limiti fondamentali nella pratica:

1. **Raggiri (Art. 1426 c.c.):** Se il minore ha occultato la sua età con raggiri (es. falsificando un documento), il contratto **non** è annullabile a tutela dell'affidamento dell'altra parte. La semplice dichiarazione verbale di essere maggiorenne non costituisce raggiro.
2. **Atti della vita quotidiana:** Nella prassi, i minori stipulano continuamente piccoli contratti (comprare la merenda, un biglietto del bus, una ricarica telefonica). La giurisprudenza li considera validi presumendo che il minore agisca come *rappresentante tacito* dei genitori e che tali atti siano adeguati alla sua capacità di discernimento.

Diritto ad esser ascoltati

Il diritto all'ascolto sancisce il passaggio del minore da mero oggetto di tutela a soggetto attivo. In ambito civilistico, l'ordinamento prevede che il minore debba essere obbligatoriamente ascoltato in tutte le questioni e i procedimenti giudiziari o sanitari che lo riguardano a partire dai **12 anni di età**, o anche prima qualora si accerti una sufficiente capacità di discernimento e maturità.

Tale ascolto rappresenta un preciso dovere processuale: ignorare l'opinione del minore in decisioni critiche, come l'affidamento genitoriale, comporta il rischio di **annullamento della sentenza**.

Traslando questo principio nella protezione dei dati, l'ascolto si evolve nel concetto di **autodeterminazione informativa**. Nel contesto dell'ecosistema digitale, il legislatore italiano applica le direttive del GDPR fissando a **14 anni** la soglia in cui si presume tale capacità di discernimento. Da quel momento, il minore viene di fatto "ascoltato" attraverso il riconoscimento del suo diritto di prestare autonomamente un consenso valido al trattamento dei propri dati personali per l'utilizzo dei servizi online. Al di sotto di tale età, invece, la **validità del consenso** resta subordinata all'autorizzazione di **chi** esercita la **responsabilità genitoriale**.

Autonomia in Rete

Nel contesto tecnologico e degli strumenti di identità digitale, l'autonomia del minore è ampiamente valorizzata:

- **Fascicolo Sanitario Elettronico (FSE):** A partire dai 14 anni, le sezioni sensibili del fascicolo vengono oscurate ai genitori e rese accessibili solo al minore.
- **Accesso ai Social Media:** In Italia, il minore raggiunge a 14 anni l'età legittima per prestare il consenso al trattamento dei dati personali e aprire un profilo social (le normative europee prevedono un range tra i 13 e i 16 anni).

Tutela contro Cyberbullismo e Revenge Porn: Il ruolo dell'Hash

Le normative offrono tutele contro cyberbullismo e *revenge porn*. Le vittime possono richiedere alle piattaforme la rimozione dei contenuti illeciti.

Cyberbullismo

La **Legge n. 71/2017** consente al minore ultraquattordicenne vittima di cyberbullismo di chiedere direttamente al gestore l'oscuramento o la rimozione. Se il gestore non provvede, il minore può rivolgersi al Garante Privacy. La normativa è stata ampliata dalla **Legge n. 70/2024**, che include il bullismo offline.

Se un minore compie atti di bullismo, dell'illecito rispondono i genitori a meno che questi non dimostrino di aver fatto tutto il possibile per evitare tale fatto (es. educazione coerente).

Caso Google/Vivi Down

Un caso fondamentale è quello di **Google/Vivi Down** (un minore disabile umiliato). La Cassazione ha escluso la responsabilità penale dei manager di Google, chiarendo che non

esiste un obbligo di sorveglianza preventiva, ma l'obbligo di agire tempestivamente dopo la segnalazione.

Age Verification (Decreto Caivano)

L'**art. 13-bis del d.l. 123/2023 (Decreto Caivano)** ha introdotto l'obbligo di verifica dell'età per l'accesso a siti pornografici tramite strumenti come SPID o CIE. Sebbene protettiva, l'efficacia è limitata dall'uso di VPN.

Revenge porn

Nel caso del revenge porn (quindi pubblicazione di un contenuto a sfondo sessuale senza il consenso di una delle parti per vendetta) se la vittima è un **minorenne**, può autonomamente far oscurare il contenuto (come detto prima). Esiste però la difficoltà delle piattaforme nell'oscurare questo tipo di contenuto

Hashing

Dal punto di vista tecnologico, per impedire che un contenuto illecito venga ricaricato, le piattaforme utilizzano le **funzioni di Hash**. Un hash è un'impronta digitale alfanumerica univoca generata a partire dal file originario. Quando un file illecito viene segnalato, il suo hash finisce in una *blacklist*; ogni nuovo upload viene scansionato e, se l'hash corrisponde, viene bloccato in automatico.

Questo sistema presenta però dei limiti tecnici:

- **Fragilità Crittografica:** In un hash crittografico standard (es. SHA-256), basta modificare un singolo pixel dell'immagine o ritagliarne un bordo per generare un hash completamente diverso, eludendo il blocco.
- **Perceptual Hashing:** Per arginare il problema, si usano algoritmi (come *PhotoDNA*) che valutano la somiglianza visiva, ma questi alzano il rischio di "falsi positivi" (bloccando immagini legittime) e sollevano dubbi sulla sorveglianza di massa e sulla privacy di tutti gli utenti della piattaforma.

Il Parental Control tra Diritto e Tecnica

I genitori conservano strumenti di vigilanza attraverso i sistemi di **Parental Control**, che rispondono sia a un'esigenza tecnica che legale. Giuridicamente, il genitore ha il dovere di educare e vigilare (Art. 30 Cost. e Art. 2048 c.c. che disciplina la *culpa in educando* e *in vigilando* in caso di illeciti commessi dal minore).

Tecnicamente, il Parental Control opera su due livelli:

- **A livello di Rete (ISP):** In Italia, l'AGCOM impone agli operatori telefonici di offrire gratuitamente sistemi di blocco preventivo dei contenuti inadatti (siti per adulti, gioco d'azzardo, armi) direttamente sulle SIM intestate ai minori.
- **A livello di Dispositivo/OS:** Strumenti integrati nei sistemi operativi (es. Family Link per Android o Screen Time per Apple) che permettono non solo il filtraggio web, ma anche il

blocco di app specifiche, la geolocalizzazione e la gestione rigorosa del tempo di utilizzo (Screen Time Limits).

D.L. 28/2020 (Art. 7-bis) - Parental Control su SIM per minori

Sistemi di protezione dei minori dai rischi del cyberspazio

- **Obbligo per gli operatori (ISP):** Preattivazione automatica (*by default*) e gratuita di sistemi di controllo parentale sulle SIM intestate a minori.
- **Filtro contenuti:** Blocco assoluto dell'accesso a siti inappropriati per l'età (pornografia, violenza, armi, ecc.).
- **Disattivazione:** Richiede l'intervento esplicito e l'identificazione (es. tramite SPID o PIN) di chi esercita la responsabilità genitoriale.
- **Attuazione tecnica: Delibera AGCOM n. 9/23/CONS** (operativa da novembre 2023), che ha fornito l'elenco standardizzato delle categorie web da inibire.

Sharenting

A queste tutele fa da contraltare il rischio dello **sharenting**: la sovraesposizione di foto e video dei figli online (o sui social) da parte dei genitori, che rischia di creare una memoria di rete eterna e di violare la futura privacy del minore. Si crea potenzialmente pure il rischio di maleintenzionati si avvicinino e ottengano fiducia del figlio sulla base delle informazioni che sono state condivise.

Per questo tipo di comportamento il figlio può richiedere un risarcimento, insieme alla cancellazione dei contenuti suddetti.

Trattamento dei Dati Personali e Normativa Contrattuale

Evoluzione Storica e Principi della Protezione dei Dati

1. Dal Segreto alla Privacy (Common Law)

Il concetto moderno nasce negli USA con il saggio di **Samuel Warren e Louis Brandeis (1890)** intitolato "*The Right to Privacy*", definito come il "*diritto di essere lasciati soli*" (right to be let alone). Inizialmente concepito come diritto negativo (esclusione di terzi), si evolve poi come dominio sulla propria immagine e informazioni.

2. La Privacy in Europa

In Europa, dopo la Seconda Guerra Mondiale, la privacy diventa un **diritto fondamentale** per proteggere la dignità contro abusi del potere pubblico (memoria dei regimi totalitari).

La **Dichiarazione Universale dei Diritti dell'Uomo (1948)** sancisce, all'Articolo 12, il diritto alla protezione della corrispondenza (oggi esteso a email e WhatsApp).

3. Tappe Normative

- **Statuto dei Lavoratori (L. 300/1970):** L'art. 4 vieta il controllo a distanza dei lavoratori tramite impianti audiovisivi, ammettendoli solo per esigenze organizzative/sicurezza e con garanzie precise (accordo sindacale).
- **Anni '70 (Germania):** Nasce il termine "protezione dei dati" (**Datenschutz**).
- **Convenzione di Strasburgo (n. 108/1981):** Il primo strumento internazionale vincolante sul trattamento automatizzato dei dati.
- **Carta dei Diritti Fondamentali dell'UE (Nizza, 2000):** Distingue nettamente tra **Art. 7** (Vita privata e familiare) e **Art. 8** (Protezione dei dati personali), rendendo quest'ultimo un diritto autonomo.

4. Dati come Beni e Mercato (GAFAM)

Nell'economia digitale, i dati sono diventati beni economici. Il Garante europeo **Giovanni Buttarelli** ha evidenziato come il problema non sia solo la singola violazione, ma il modello economico dei **GAFAM** (Google, Apple, Facebook, Amazon, Microsoft) basato sulla massimizzazione del valore dei dati.

Il bilanciamento tra la libertà di informazione e la protezione dei dati si fonda su tre caratteristiche/limiti fondamentali (diritto di cronaca):

1. **Verità/Verosimiglianza:** la notizia deve corrispondere al vero o essere seriamente accertata.
2. **Continenza:** la forma dell'esposizione deve essere corretta, utilizzando termini non intrinsecamente ingiuriosi.
3. **Pertinenza:** le informazioni divulgate devono essere strettamente necessarie per realizzare la finalità del contenuto. Ad esempio, se un minore è coinvolto in una notizia, i suoi **Dati personali** possono essere diffusi solo se sussiste un preminente interesse pubblico o del minore stesso.

Carta di Treviso

Stabilisce i doveri deontologici dei giornalisti per la tutela dei minori. Molti di questi principi sono stati successivamente integrati in norme e leggi vincolanti.

Va ricordato che i diritti legati alla privacy non sono assoluti, ma subiscono limitazioni nel bilanciamento con altri diritti fondamentali. Il termine stesso relativo alla "protezione dei dati" nasce storicamente in Germania negli anni '70.

❗ **Inserire qui la slide relativa alla nascita della normativa sulla protezione dei dati in Germania negli anni '70.**

L'evoluzione normativa è passata attraverso tappe fondamentali come la L. 300/1970 (**Statuto dei Lavoratori**, poi aggiornato col **Jobs Act**) e la **Convenzione di Strasburgo** (1981).

II GDPR (2016)

Il Regolamento (UE) 2016/679 (GDPR) rappresenta il pilastro normativo europeo relativo alla protezione delle persone fisiche con riguardo al Trattamento dei **Dati Personali**, nonché alla libera circolazione di tali dati. L'obiettivo principale è proteggere i diritti e le libertà fondamentali dell'Interessato, ponendo un focus specifico proprio sul diritto alla protezione dei dati personali e regolamentandone i flussi.

I Beni e i Requisiti Essenziali del Contratto

Nel diritto civile, i beni sono definiti come le "cose che possono formare oggetto di diritti" (Art. 810 c.c.).

Il codice civile distingue ulteriormente i beni all'Art. 812 c.c. (beni immobili e beni mobili) e all'Art. 814 c.c., che equipara ai beni mobili le energie naturali che hanno un valore economico. Non tutti i beni sono necessariamente "cose" materiali. Il legislatore prevede requisiti di forma specifici (es. forma scritta a pena di nullità) per documentare il trasferimento di determinati beni.

❗ Differenza giuridica

Il furto consiste nell'appropriazione indebita di un *bene mobile*, mentre l'occupazione è un reato che si configura su un *bene immobile*.

L'Art. 1321 c.c. definisce il **Contratto** come "l'accordo di due o più parti per costituire, regolare o estinguere tra loro un rapporto giuridico patrimoniale".

Affinché sia valido, l'Art. 1325 c.c. impone i seguenti requisiti essenziali:

- L'accordo delle parti.
- La causa.
- L'oggetto.
- La forma (quando prescritta dalla legge sotto pena di nullità).

Oggetto del Contratto e Rilevanza dell'Errore

L'oggetto del contratto non coincide necessariamente con un bene materiale. Ad esempio, nella compravendita, l'oggetto è il trasferimento del diritto di proprietà sulla cosa (a fronte di un

prezzo assunto come corrispettivo), non la cosa in sé.

Esempio

Il Patto di non concorrenza è un contratto il cui oggetto non attiene a una cosa materiale, ma a un'obbligazione di "non fare".

L'errore è causa di annullamento del contratto (Art. 1428 c.c.) quando è **essenziale** e **riconoscibile** dall'altro contraente. Secondo l'Art. 1429 c.c., l'errore è essenziale quando cade:

1. Sulla natura o sull'oggetto del contratto.
2. Sull'identità dell'oggetto della prestazione o sopra una qualità dello stesso che, secondo il comune apprezzamento e in relazione alle circostanze, deve ritenersi determinante del Consenso.

Dati Personali come Controprestazione e Modello Pay-or-Consent

La legislazione recente ha iniziato a riconoscere il valore economico dei Dati Personali all'interno dei contratti digitali, introducendo tutele specifiche.

Capo I-bis dei contratti di fornitura di contenuto digitale e di servizi digitali (D.Lgs. 173/2021) - Art. 135-octies

Disciplina gli aspetti dei contratti tra consumatore e professionista, inclusa la conformità del servizio, i rimedi in caso di difetto e le modalità di modifica del contenuto.

Particolare rilevanza assume il **comma 4 dell'Art. 135-octies**.

Art. 135-octies, comma 4

Le disposizioni si applicano anche quando il professionista fornisce un servizio digitale e il consumatore fornisce (o si obbliga a fornire) Dati Personali al professionista, tranne se i dati sono trattati *esclusivamente* per fornire il servizio o per assolvere obblighi di legge, senza scopi ulteriori.

Questa impostazione è supportata anche dalla giurisprudenza di merito, che evidenzia la natura di scambio in questi rapporti. Affinché il trattamento sia lecito, il Consenso dell'utente deve sempre essere revocabile.

Tribunale di Bologna, ordinanza 10 marzo 2021

L'utente, ogni volta che consente l'utilizzo e la diffusione dei propri dati a scopo commerciale, fornisce al gestore del servizio digitale, con un atto negoziale dispositivo, una controprestazione patrimonialmente valutabile. Questo evidenzia il carattere oneroso del rapporto negoziale, fondato su un evidente sinallagma: alla prestazione del servizio corrisponde l'interesse del gestore a utilizzare dati e reti di relazioni a fini di raccolta pubblicitaria.

Ordinanza Trib. Bologna (10 marzo 2021) • Dati e Social Network

- **Il Caso:** Facebook cancella immotivatamente il profilo personale e la pagina aziendale di un utente.
- **Natura del Contratto:** I social *non sono gratuiti*. Il contratto è **sinallagmatico** (a prestazioni corrispettive): l'utente cede i propri **dati personali a scopo commerciale** (profilazione/advertising) in cambio dell'uso della piattaforma (in linea con la *Direttiva UE 2019/770*).
- **Inadempimento:** La cancellazione *ad nutum* (senza specifica motivazione o violazione provata) è contraria ai doveri di **buona fede e correttezza** (artt. 1175 e 1375 c.c.).
- **Danno Risarcibile:** L'account è una proiezione dell'**identità digitale** e uno strumento di sviluppo della personalità (art. 2 Cost.). La sua perdita ingiustificata lede la *vita di relazione* (danno non patrimoniale).

Le Linee Guida EDPB sul modello "Consenti o Paga"

Il dibattito sull'uso dei dati come controprestazione si è acceso con l'introduzione dei modelli *Pay-or-Consent* (consenti o paga) da parte delle grandi piattaforme online (es. per la pubblicità comportamentale).

Alcune Autorità di Controllo (Garante Privacy) hanno richiesto all'EDPB (European Data Protection Board) un parere (ispirato anche dalla sentenza della CGUE C-252/21) per stabilire se e quando queste scelte costituiscano un Consenso valido e liberamente prestato.

I punti chiave (rif. della prof. Stefanelli):

- **Scelta binaria insufficiente:** Nella maggior parte dei casi, presentare agli utenti *solo* una scelta binaria tra "acconsentire al tracciamento per pubblicità comportamentale" o "pagare una tariffa" non soddisfa i requisiti del GDPR per un consenso valido.
- **Alternativa equivalente:** Le grandi piattaforme (Very Large Online Platforms - VLOPs) dovrebbero fornire agli interessati un'"alternativa equivalente" che non comporti il pagamento in denaro.
- **Terza opzione gratuita:** Dovrebbe essere considerata l'offerta di un'ulteriore alternativa gratuita priva di pubblicità comportamentale (ad esempio, sostenuta da pubblicità contestuale che comporta un Trattamento di dati personali minimo o nullo).

Fondamenti di Cybersicurezza, Gestione del Rischio e Normativa

Il Rischio Cyber e il Ruolo del DPO

La sicurezza informatica è intrinsecamente associata al concetto di rischio. In Italia, istituzioni e associazioni come l'Agenzia per la Cybersicurezza Nazionale (ACN) e il CLUSIT (attraverso l'annuale Rapporto Clusit) monitorano costantemente le tendenze e l'andamento delle minacce in ambito cyber a livello nazionale e globale. I rischi informatici sono in continua ed esponenziale espansione, con un boom significativo registrato durante la pandemia da COVID-19, portando a una chiara partizione percentuale dei tipi di attacco.

Nell'ambito del GDPR, l'articolo 39 stabilisce i compiti del Data Protection Officer (DPO), il quale ha il ruolo di supportare il Titolare del trattamento nell'attribuire le responsabilità interne e nel sensibilizzare e formare il personale sui rischi connessi al trattamento dei dati personali. Ciò significa che il DPO e le figure preposte devono conoscere approfonditamente le minacce informatiche più comuni (es. accesso abusivo, malware) per poter adeguare procedure e adottare adeguate misure tecniche e organizzative.

Articolo 39 GDPR

Definisce i compiti del DPO, tra cui la sorveglianza dell'osservanza del regolamento e la sensibilizzazione e formazione del personale che partecipa ai trattamenti.

Collaborazione

È fondamentale la collaborazione e l'interscambio tra informatici, tecnici e giuristi per una corretta compliance aziendale. Al giorno d'oggi vi è un preciso obbligo di possedere competenze informatiche anche per le professioni legali e gli avvocati (es. caso Panama Papers).

Standard Internazionali e Valutazione del Rischio

Un elemento centrale nella gestione aziendale è l'approccio basato sul rischio (Risk Management). Lo standard **ISO 31000** fornisce lo scheletro e le linee guida per un corretto impianto normativo e di processo.

Struttura ISO 31000

Si articola in due componenti principali:

1. **Framework:** Garantisce che la gestione del rischio sia integrata in tutte le attività (Leadership, Integrazione, Progettazione, Attuazione, Valutazione e Miglioramento).
2. **Processo:** L'applicazione operativa che include l'identificazione, l'analisi (stima di probabilità e impatto), la valutazione (confronto con i criteri di accettabilità) e il trattamento del rischio.

La formula fondamentale per la valutazione del rischio è **$R = P \times D$** (Rischio = Probabilità x Danno/Impatto).

Analisi Qualitativa vs Quantitativa

- **Qualitativa:** Si basa su scale descrittive (es. alto/medio/basso) e giudizi esperti. È utile quando i dati numerici sono limitati o per una valutazione rapida. Utilizza matrici di rischio per visualizzare la criticità.
- **Quantitativa:** Impiega dati numerici e metodi statistici (es. simulazioni *Monte Carlo*) per calcolare la perdita attesa in termini monetari, come l'**ALE** (*Annual Loss Expectancy*). La formula standard è **$ALE = SLE \times ARO$** , dove *SLE* (*Single Loss Expectancy*) è la perdita per singolo evento e *ARO* (*Annual Rate of Occurrence*) è la frequenza annuale ipotizzata. Richiede dati storici affidabili e competenze specialistiche.

Lo schema di valutazione si appoggia a modelli ciclici come il Ciclo di Deming (**PDCA**: Plan-Do-Check-Act) per garantire un miglioramento continuo (Kaizen) dei processi di gestione.

Classificazione delle Minacce e Motivazioni

Le minacce informatiche possono essere classificate secondo diversi criteri per meglio comprendere il profilo di rischio:

1. Motivazione dell'Attaccante

- **Economica:** Il fine principale è il lucro (estorsione tramite ransomware, furto di credenziali bancarie, rivendita di dati nel dark web).
- **Spionaggio:** Attacchi mirati ad acquisire informazioni sensibili, segreti industriali o dati strategici di governi, spesso condotti in modo discreto per lungo tempo.
- **Ideologica (Hacktivismo):** Attacchi mossi da motivazioni politiche o sociali (es. Anonymous) per ottenere clamore mediatico tramite *DDoS* o *Defacement* (modifica non autorizzata della home page di un sito).
- **Advanced Persistent Threat (APT):** Minacce sofisticate condotte da attori statali o gruppi terroristici con notevoli risorse, che mirano a mantenere un accesso prolungato e non rilevato all'interno di un sistema.

2. Fonte e Superficie d'Impatto

Le minacce possono essere **interne** (dipendenti infedeli o negligenti) o **esterne**. La superficie d'impatto si estende su quattro ambiti:

- **Software:** Vulnerabilità del codice (es. *SQL Injection*, *Cross-Site Scripting*).
- **Hardware e Rete:** Componenti fisiche e infrastrutture di comunicazione.
- **Supply Chain:** Attacchi alla catena di approvvigionamento (es. compromettere un fornitore per colpire il cliente finale).
- **Fattore Umano:** Definito nell'ambiente hacker come **Wetware** (l'hardware biologico o software mentale), rappresenta la superficie più critica.

La resilienza informatica è diventata un pilastro strategico. In Unione Europea si pone forte accento sulla "sovranità digitale" per ridurre la dipendenza da tecnologie e software extra-UE (es. software americani o asiatici), come testimoniato dall'adozione di normative quali l'European Chips Act.

Fondamenti di Sicurezza: La Triade CIA

I reati informatici e le violazioni di sicurezza incidono quasi sempre su almeno uno dei tre elementi fondamentali della sicurezza delle informazioni.

CONCETTO IMPORTANTE: La Triade CIA.

La Triade CIA si compone di:

- **Confidentiality (Confidenzialità):** i dati devono poter essere letti ed elaborati esclusivamente da figure specifiche e autorizzate.
- **Integrity (Integrità):** l'informazione non deve subire alterazioni; se un soggetto non abilitato modifica i dati, l'integrità è compromessa.
- **Availability (Disponibilità):** i dati devono essere prontamente accessibili ai soggetti autorizzati, impedendone l'esposizione ai non autorizzati.

Evoluzione Storica della Cybersicurezza

La sicurezza informatica non è nata contemporaneamente all'informatica: i primissimi sistemi non contemplavano il concetto di "sicurezza by design". Oggi, la cybersecurity riguarda e tutela sia le componenti hardware (es. mitigazione di vulnerabilità delle CPU come *Meltdown* basate su segnali anomali) sia quelle software.

 **Fun fact: la derivazione del termine "bug" ha origine al MIT (e poi ad Harvard sul Mark II) per via di un insetto reale incastrato nei circuiti della macchina, il primo vero "bug" della storia dell'informatica.**

Negli anni '50, i primi Big Mainframe come l'UNIVAC (1951) non avevano cyber-sicurezza. La protezione dell'hardware era esclusivamente fisica, volta a prevenire il danneggiamento più che il furto. La programmazione avveniva in linguaggio macchina (0 e 1), esponendo i sistemi a frequenti errori umani. In assenza di connessioni esterne, l'accesso fisico alla sala server fungeva da unica vera "autenticazione". Successivamente, con calcolatori come il Mark 1 (Harvard) basato su componenti meccanici (e con antenati come il Meccanismo di Anticitera di Archimede per calcoli astronomici), l'informatica si è evoluta. Con la nascita di ARPANET prima di Internet (anni '70), sono emerse le fondamenta della cybersicurezza moderna.

📌 **Esempio storico-culturale: il film "WarGames" e lo spavento del Presidente Reagan, che diede impulso alle primissime policy governative di sicurezza informatica negli USA.**

Poiché i profili di rischio evolvono continuamente, è essenziale comprendere che la "sicurezza assoluta" in informatica non esiste.

Il Quadro Normativo Nazionale e la Direttiva NIS

Una violazione di sicurezza che comporta accidentalmente o in modo illecito la distruzione, la perdita, la modifica, la divulgazione non autorizzata o l'accesso ai dati personali trasmessi, conservati o comunque trattati, configura giuridicamente un Data Breach (violazione dei dati personali).

Il legislatore interviene costantemente per arginare tali minacce. A livello europeo, la materia è presidiata dalla **Direttiva NIS2 (Reg. UE 2022/2555)**, che mira a eliminare le frammentazioni tra gli Stati membri espandendo i settori coinvolti e armonizzando i requisiti di sicurezza.

Punti chiave della NIS2:

- **Classificazione Soggetti:** Distingue tra *Soggetti Essenziali* (settori critici come energia, sanità, banche) sottoposti a vigilanza proattiva e *Soggetti Importanti* sottoposti a vigilanza reattiva.
- **Obblighi di Segnalazione:** Obbligo di notifica degli incidenti significativi alle autorità competenti (CSIRT) entro tempistiche stringenti.
- **Sanzioni:** Possono arrivare fino al **6% del fatturato annuo mondiale** del prestatore.

A livello nazionale, il quadro include la **Legge 90/2024**, che consolida le attribuzioni dell'Agenzia per la Cybersicurezza Nazionale (ACN) e introduce la figura del **"Referente per la cybersicurezza"** in ogni PA. Il Decreto Legge 105/2019 sul Perimetro di Sicurezza Nazionale Cibernetica e il Decreto Legge 138/2024 completano l'impianto, estendendo la protezione ad asset strategici.

✍️ **Decreto Legge 20/2021: Introduce raccomandazioni cogenti per la Pubblica Amministrazione, suggerendo fortemente di dismettere l'utilizzo di software russi**

(come gli antivirus Kaspersky) per arginare il rischio concreto di "backdoor" governative.

Minacce, Fattore Umano e Social Engineering

L'anello debole della catena di sicurezza rimane l'utente. Spesso ci si riferisce al fattore umano con l'espressione "Problem Exists Between the Keyboard And the Chair" (PEBKAC). Aggiungendo specifiche motivazioni psicologiche, è possibile manipolare l'output e il comportamento delle persone.

Questa tecnica prende il nome di **Ingegneria Sociale (Social Engineering)**, che sfrutta le debolezze cognitive per ottenere accessi o informazioni riservate. Le caratteristiche e leve principali sfruttate sono:

- Autorevolezza
- Senso di colpa
- Panico
- Ignoranza
- Desiderio
- Avidità
- Compassione

Oltre alle leve psicologiche, l'ingegneria sociale utilizza tecniche fisiche e verbali specifiche:

- **Tailgating:** Seguire fisicamente una persona autorizzata all'interno di un'area protetta senza mostrare credenziali.
- **Piggybacking:** Simile al tailgating, ma avviene con la cooperazione o la disattenzione della persona autorizzata (es. farsi tenere aperta la porta).
- **Pretexting:** Creare uno scenario falso (un pretesto) per convincere la vittima a rivelare informazioni (es. fingersi un tecnico dell'assistenza IT).
- **Quid Pro Quo:** Offrire un servizio o un vantaggio in cambio di informazioni (es. "ti aiuto a risolvere un problema al PC se mi dai la password").
- **Dumpster Diving:** Ricerca di informazioni sensibili tra i documenti cartacei scartati e non distrutti correttamente.

 **Lettura consigliata: "The Art of Deception" (L'arte dell'inganno) di Kevin Mitnick, testo fondamentale sulle tecniche di Social Engineering.**

Tipologie di Attacchi e Malware

Le reti sono esposte a diverse categorie di software malevolo, comunemente note come Malware. Una delle minacce più perniciose è il **Ransomware**, che cifra i dati dell'interessato e delle aziende estorcendo un riscatto economico. Le tipologie includono:

- **Locker:** blocca completamente l'accesso al sistema.
- **Crypto:** cifra specificamente i file rendendoli illeggibili.
- **Double Extortion:** oltre a cifrare, minaccia la divulgazione pubblica dei dati esfiltrati.
- **Ransomware as a Service (RaaS):** un modello criminale in abbonamento per l'utilizzo di ransomware da parte di terzi.

Ulteriori tipologie di attacchi includono attacchi per intercettazione, come il *Man in the Middle* o il *Man in the Mail* (es. Business Email Compromise), spesso orchestrati da grandi organizzazioni criminali. A livello di cyber-warfare governativo, si ricorda il celebre virus *Stuxnet*, creato ad hoc per distruggere le centrifughe del sistema di arricchimento dell'uranio in Iran o l'exploit **EternalBlue** usato per la diffusione di WannaCry.

Tra le nuove minacce emergenti, manipolazioni tramite intelligenza artificiale o minacce fisiche:

- **Deepfake**

Manipolazione Subliminale

Utilizzo di IA per creare contenuti audio/video falsi estremamente realistici. Oltre alla truffa (es. Nigerian Scam evoluta o frodi del CEO), il Deepfake lede la privacy e può essere usato per la manipolazione cognitiva bypassando i filtri razionali dell'utente, influenzando processi decisionali e opinione pubblica.

- **BadUSB (Rubber Ducky)**

Vettore di Infezione Hardware

Dispositivi apparentemente innocui (come le chiavette USB "Rubber Ducky") che vengono riconosciuti dal sistema non come memorie di massa, ma come tastiere (HID). Una volta collegati, digitano sequenze di comandi pre-programmati ad altissima velocità, permettendo l'esecuzione di script malevoli, l'apertura di backdoor o l'esfiltrazione di dati in pochi secondi, aggirando molti controlli di sicurezza tradizionali.

Tattiche e Tecniche: Il Framework MITRE ATT&CK

Per standardizzare la descrizione degli attacchi, si utilizza il framework **MITRE ATT&CK**, una base di conoscenza mondiale sulle tattiche e tecniche degli avversari.

Tattiche vs Tecniche

- **Tattiche:** Rappresentano il "**perché**" dell'attaccante (l'obiettivo strategico, es. *Initial Access*, *Lateral Movement*, *Exfiltration*).
- **Tecniche:** Rappresentano il "**come**" l'attaccante raggiunge l'obiettivo (il metodo specifico, es. *Phishing* per l'accesso iniziale o *Pass-the-Hash* per il movimento laterale).

Il framework identifica diverse fasi nel ciclo di vita di un attacco (kill chain), tra cui:

1. **Reconnaissance:** Raccolta informazioni sul bersaglio.
2. **Resource Development:** Preparazione di strumenti (malware, server C2).
3. **Execution:** Esecuzione di codice malevolo sul sistema.
4. **Persistence:** Mantenimento dell'accesso anche dopo il riavvio.
5. **Privilege Escalation:** Ottenimento di permessi di amministratore.
6. **Defense Evasion:** Elusione dei sistemi di sicurezza (antivirus, log).
7. **Credential Access:** Furto di nomi utente e password.
8. **Discovery:** Esplorazione del sistema per capire "dove ci si trova".
9. **Lateral Movement:** Spostamento all'interno della rete per raggiungere nuovi sistemi.
10. **Collection:** Raccolta dei dati di interesse.
11. **Command and Control (C2):** Comunicazione con i sistemi infetti per impartire ordini.
12. **Exfiltration:** Sottrazione e invio dei dati verso l'esterno.
13. **Impact:** Manipolazione, interruzione o distruzione di dati e sistemi.

Successione Mortis Causa ed Eredità Digitale

Succesione

La disciplina della Successione mortis causa (**Libro II del Codice Civile**) risponde all'esigenza fondamentale per cui, alla morte di un soggetto, i suoi diritti patrimoniali non diventino *res nullius* (cosa di nessuno o diritto di nessuno). Una cosa abbandonata, infatti, sarebbe suscettibile di apprensione da parte di chiunque.

Proprietà

Storicamente (prima della Rivoluzione Francese), la concezione di proprietà era **assoluta**: il proprietario era sovrano del bene e poteva disporre liberamente, occupandosi della

successione in totale autonomia. Successivamente, è stato introdotto il principio della tutela dei **Legittimari** (gli eredi a cui la legge riserva obbligatoriamente una quota di eredità).

L'asse ereditario si divide pertanto in due quote:

- **Quota di riserva (o legittima):** la porzione di eredità che spetta di diritto ai legittimari.
- **Quota disponibile:** la porzione di patrimonio della quale il testatore può decidere autonomamente.

Warning

Se il testatore, tramite testamento o donazioni in vita, lede la quota di riserva, i legittimari possono intentare un'azione di riduzione per reintegrare la propria quota (sanando la cosiddetta **lesione della legittima**).

Info

Curiosità storica: in passato la rappresentanza politica e i diritti connessi alla proprietà non spettavano a tutti, ma dipendevano dal livello del censo (es. l'asino di Garibaldi che garantiva il requisito patrimoniale per il voto).

Forme di Testamento e Limiti del Digitale

Per evitare la distruzione o l'alterazione delle volontà del testatore, l'ordinamento prevede specifiche forme di testamento, tutte dotate della medesima efficacia probatoria. In caso di più testamenti, prevale sempre quello recante la data più recente per le disposizioni incompatibili.

1. **Testamento Olografo:** Redatto, datato e sottoscritto interamente di proprio pugno dal **testatore**. In caso di contenzioso, è **soggetto a perizia grafologica** (in cui il parere del CTU, il perito d'ufficio nominato dal giudice, ha peso preponderante).
2. **Testamento Pubblico:** Redatto dal notaio alla presenza di due testimoni. Il notaio accerta l'identità e la capacità di intendere e di volere del testatore, riducendo al minimo i vizi di forma. Viene conservato dal notaio e aperto alla morte del testatore.
3. **Testamento Segreto:** Può essere scritto anche a macchina, sigillato e consegnato personalmente al notaio, che redige un verbale di ricevimento.

Info

Allo stato attuale, l'ordinamento italiano non ammette il testamento in forma puramente digitale (es. tramite firma digitale o video-testamento). Oltre al ritardo normativo, vi è un problema concettuale: la morte fisica non implica la "morte digitale".

Info

Prassi emergenti non convenzionali: la consegna di credenziali di account (con i rischi di utilizzo antecedente alla morte) o la creazione di avatar post-mortem addestrati tramite IA.

☰ **Genitori che commissionano avatar basati sull'IA dei figli deceduti per elaborare il lutto, sollevando complessi problemi bioetici e di tutela dell'identità personale.**

Contenuto Atipico del Testamento

Oltre alle disposizioni patrimoniali, il testamento può contenere:

- **Riconoscimento** di un **debito** che gli eredi devono saldare (non può esser superiore alla proprietà).
- **Riconoscimento** di un **figlio** (disposizione **irrevocabile**).
- **Diseredazione**: clausola con cui si escludono determinati successibili legittimi.

☰ **Un caso arrivato in Cassazione ha confermato la validità di un testamento in cui il testatore si era limitato a diseredare una specifica persona (per comportamenti tenuti verso di lui e i suoi fratelli), riconoscendo implicitamente i fratelli come eredi effettivi.**

Nota di revisione (PDF): Esiste una tesi (riportata nel PDF) secondo cui il testamento non può contenere *solo* clausole negative, ma deve avere almeno una disposizione attributiva minima.

Gradi di Parentela e Diritti Intrasmisibili

Per determinare la chiamata all'eredità è fondamentale il calcolo del grado di parentela.

Art. 75 Codice Civile - Linea Collaterale

La Linea collaterale definisce il legame tra persone che condividono un antenato comune (Stipite) ma non discendono l'una dall'altra (es. fratelli = 2° grado; zii/nipoti = 3° grado; cugini = 4° grado).

Eccezioni alla successione:

- **Diritti lavorativi:** Non si trasmettono *mortis causa* (l'erede non subentra nel posto di lavoro del defunto).

- **Diritti della personalità:** Sebbene intrasmissibili, in caso di lesione dell'identità o della reputazione del defunto, gli eredi possono agire in giudizio per il risarcimento dei danni o l'inibitoria, poiché tale offesa lede anche la sfera familiare.

Eredità Digitale e Rapporto con il GDPR

Il GDPR disciplina primariamente il rapporto tra l'Interessato (persona fisica in vita) e il Titolare del trattamento.

Considerando 27 GDPR

Il Regolamento non si applica ai dati personali delle persone decedute. Gli Stati membri possono prevedere norme riguardanti il trattamento dei dati personali delle persone decedute.

Art. 6, par. 1, lett. f) GDPR

Costituisce base giuridica il trattamento necessario per il perseguimento del **Legittimo interesse** del titolare del trattamento o di terzi (es. accesso a cartelle cliniche, dati pensionistici o bancari da parte degli eredi).

L'approccio Italiano: Art. 2-terdecies del Codice Privacy

Per colmare il vuoto normativo, l'Italia ha introdotto specifiche disposizioni per l'esercizio dei diritti sui dati dei defunti.

Art. 2-terdecies Codice Privacy (D.lgs 196/2003, introdotto dal D.lgs 101/2018)

1. I diritti (artt. 15-22 GDPR) riferiti a persone decedute possono essere esercitati da chi ha un **interesse proprio**, o agisce a tutela dell'interessato in qualità di **mandatario**, o per **ragioni familiari meritevoli di protezione**.
2. L'esercizio di tali diritti non è ammesso se l'interessato lo ha espressamente vietato con dichiarazione scritta al Titolare del trattamento.
3. La volontà di vietare l'accesso deve essere **non equivoca, specifica, libera e informata**.
4. Il divieto è sempre revocabile o modificabile.
5. **Limite al divieto:** il divieto dell'interessato non può mai pregiudicare l'esercizio da parte di terzi dei diritti patrimoniali derivanti dalla morte dell'interessato o il diritto di difendere in giudizio i propri interessi.

- ☰ Un testatore può lasciare disposizioni digitali selettive: le foto in un servizio cloud a una specifica persona, i dati del wallet digitale agli eredi legittimi.

- ☰ **Caso clinico/Ereditario:** Una donna agisce in giudizio per il riconoscimento di paternità. Il presunto padre muore e nomina un altro erede universale, il quale fa cremare la salma per impedire il test del DNA e non cedere la quota di legittima. La donna scopre che una bio-banca conserva tessuti biologici dell'uomo. L'erede tenta di bloccare l'accesso invocando la privacy del defunto. Il giudice autorizza l'accesso: il divieto di accesso ai dati (o ai campioni) non può ledere il diritto della donna di difendere in giudizio il proprio interesse (riconoscimento dello status di figlia ed eredità).

Diritto di Accesso ai Dati del Defunto: Italia vs Germania

La giurisprudenza europea non è uniforme sulle basi legali con cui gli eredi accedono ai dati digitali. In Italia, se fosse negato l'accesso, verrebbe di fatto impedito il subentro nelle posizioni giuridiche patrimoniali. Inoltre, le clausole standard dei provider (es. "intrasferibilità dell'account") non costituiscono un divieto "specifico, libero e informato" valido ex art. 2-terdecies.

Ordinamento	Approccio adottato	Principio Giuridico
Italia	Personalistico	Persistenza di interessi giuridicamente tutelabili in capo a chi agisce (ragioni familiari meritevoli o interesse proprio).
Germania	Patrimonialistico	Principio di universalità della successione: gli asset digitali sono equiparati al patrimonio materiale.

Casi Giurisprudenziali di Eredità Digitale

1. **Caso Facebook (Germania, 2018):** Il Bundesgerichtshof ha stabilito il principio della **successione universale** negli account social. Gli eredi subentrano nel contratto con la piattaforma e possono accedere alle chat private del defunto (nel caso, una minore morta in metropolitana), prevalendo sulle policy di riservatezza della piattaforma.
2. **Caso Apple (Tribunale di Roma):** Una vedova ha ottenuto tramite ricorso d'urgenza (**ex art. 700 c.p.c.**) l'accesso all'iCloud del marito per recuperare foto e video familiari. Il giudice ha valorizzato le "ragioni familiari meritevoli di protezione" contro le clausole contrattuali di Apple.
3. **Caso dello Chef:** Una famiglia ha richiesto l'accesso al cloud di uno chef deceduto per recuperare ricette inedite. Apple ha opposto resistenza richiamando la privacy, ma il tribunale ha tutelato l'interesse degli eredi a pubblicare il libro e preservare la memoria.

Problema Contrattuale: Clausole "Assurde"

Per dimostrare che gli utenti accettano ToS senza leggerli, alcune aziende inseriscono clausole provocatorie:

- **Clausola Zombie (Amazon):** clausola che regola il servizio in caso di apocalisse zombie.
- **Clausola Erode:** clausola che prevede la preferenza per il figlio primogenito maschio nell'accesso al Wi-Fi.

Ciò solleva il problema dell'effettività del consenso nei contratti digitali.

La Responsabilità delle Piattaforme: Dal "Just Hosting" alla Tutela dei Diritti

Le Piattaforme Digitali: Tra Libertà di Impresa e Necessità di Regolamentazione

L'avvento e la diffusione massiva delle piattaforme digitali impongono un delicato bilanciamento di interessi. Da una parte vi è l'esistenza stessa di questi fornitori di servizi, che necessitano di operare senza un carico normativo che ne paralizzi il modello di business; dall'altra vi è la necessità di **tutelare** gli *utenti* e i *terzi*.

L'ordinamento europeo (dalla **Direttiva e-Commerce** al recente **Digital Services Act**) ha storicamente evitato di imporre obblighi generali di sorveglianza preventiva: monitorare attivamente e a priori la mole titanica di dati generati dagli utenti è tecnicamente e organizzativamente inesigibile. Per questo motivo, le piattaforme sono state inquadrate inizialmente come fornitori di servizi di Hosting Provider passivo ("just hosting"), godendo di un regime di esenzione della responsabilità per i contenuti caricati dagli utenti, a patto di non averne conoscenza effettiva.

Potere Privato, Termini di Servizio e Rischio Censura

Il **rapporto** tra piattaforma e utente è regolato da un contratto, incarnato nei **Termini di Servizio (ToS)**. Quando le regole d'uso non vengono rispettate, la piattaforma esercita il suo potere contrattuale sanzionando l'utente, spesso tramite la sospensione o il ban dell'account.

Tuttavia, la scala raggiunta dalle Big Tech ha mutato la natura di questo rapporto. Le piattaforme non esercitano più un mero potere contrattuale paritetico, ma detengono poteri privati pseudo-normativi su quelli che sono diventati i nuovi "spazi pubblici" digitali. Questa asimmetria genera un **rischio concreto di censura**: una moderazione **algoritmica** o umana opaca e arbitraria può **silenziare voci legittime**, mettendo a rischio la **libertà** di espressione e, in ultima analisi, i **processi democratici** stessi.

La Responsabilità della Piattaforma: Contrattuale vs Extracontrattuale

Bisogna distinguere la natura della responsabilità della piattaforma (Art. 1218 vs 2043 c.c.):

- **Responsabilità Extracontrattuale (2043 c.c.):** Prescrizione in **5 anni**. L'onere della prova è totalmente a carico del danneggiato (fatto, dolo/colpa, danno, nesso causale).
- **Responsabilità Contrattuale (1218 c.c.):** Prescrizione in **10 anni**. L'onere della prova è invertito: il debitore (piattaforma) deve provare che l'inadempimento non gli è imputabile.
- **Contatto Sociale Qualificato:** La giurisprudenza ha esteso la responsabilità contrattuale anche in assenza di contratto formale quando esiste un rapporto qualificato (es. Medico/Paziente o Piattaforma/Utente basato su obblighi di protezione di legge).

Il Digital Services Act (DSA - Reg. UE 2022/2065)

Il DSA armonizza le regole UE:

- **Contenuto Illegale:** Definito come qualsiasi informazione non conforme al diritto UE o nazionale.
- **Notice and Action (Art. 16):** Meccanismi user-friendly per segnalare illeciti.
- **Motivazione (Art. 17):** Obbligo di spiegare all'utente perché un contenuto è stato rimosso.
- **Sanzioni:** Fino al **6% del fatturato annuo mondiale** per violazioni gravi.

Evoluzione Giurisprudenziale: Illiceità Manifesta

La **Cassazione n. 7708/2019** ha stabilito che l'hosting provider è responsabile se non rimuove contenuti la cui **illiceità è manifesta** (es. diffamazione evidente, deep fake palesi, immagini intime). Se l'illiceità non è manifesta, il provider non deve farsi "giudice" ma segnalare alle autorità.

Casi Simbolici

1. **The Pirate Bay:** Caso di condivisione P2P. Oltre alla rimozione, è fondamentale la **deindicizzazione** (taglio dei link dai motori di ricerca) per rendere il contenuto irraggiungibile.
2. **Caso Tiziana Cantone:** Diffusione non consensuale di contenuti intimi. Ha evidenziato il **danno catastrofico** (sofferenza lucida prima del suicidio) che si trasmette agli eredi, e il danno da perdita del rapporto parentale per i familiari.

Confronto Modelli Globali

- **USA (Section 230):** Ampia immunità per le piattaforme (non considerate "editori" dei contenuti utenti). Modello che protegge molto l'innovazione ma meno le vittime.

- **Cina e Corea del Sud:** Controllo statale pervasivo e obblighi di sorveglianza intensi, a scapito della libertà di espressione.
- **Modello Europeo (Via Intermedia):** Nessun controllo preventivo generale (per evitare censura privata), ma obblighi di diligenza, trasparenza e reattività (*Notice and Action*).

La Tutela dei Terzi: Il Fatto Illecito e i Danni

Un'ulteriore e cruciale problematica si verifica quando i contenuti pubblicati in violazione delle regole d'uso (es. diffamazione, cyberbullismo, hate speech) generano un danno a soggetti terzi.

 **In base all'Art. 2043 c.c. (Responsabilità extracontrattuale o aquiliana), qualunque fatto doloso o colposo che cagiona ad altri un danno ingiusto, obbliga colui che ha commesso il fatto (e in certi casi chi ne ha agevolato il mantenimento) a risarcire il danno.**

L'ordinamento civile suddivide le conseguenze lesive in diverse categorie, partendo dall'esempio classico dell'aggressione (una rissa fisica, che nel digitale si traduce in linciaggio mediatico o aggressione verbale):

- **Danno Patrimoniale:** La lesione del patrimonio del soggetto, che si divide in danno emergente (spese sostenute, es. cure mediche o legali) e lucro cessante (mancato guadagno).
- **Danno Non Patrimoniale:** Comprende diverse sfaccettature che ledono la persona e non il portafoglio:
 - **Lesione del Diritto alla Salute (Danno Biologico):** Lesione dell'integrità psico-fisica accertabile medico-legalmente.
 - **Danno Esistenziale:** Il peggioramento oggettivo della qualità della vita e l'alterazione delle abitudini quotidiane.
 - **Danno Morale:** La sofferenza interiore e il turbamento transitorio. Un classico esempio giurisprudenziale (anche se in ambito contrattuale/consumeristico) è il Danno da Vacanza Rovinata: se il tour operator promette determinati servizi e l'utente subisce un inadempimento grave, quest'ultimo ha diritto al risarcimento sia per i danni patrimoniali (il costo della vacanza non goduta), sia per i danni morali (lo stress, la frustrazione e il tempo di riposo irrimediabilmente perso).

La Responsabilità Extracontrattuale (Art. 2055 c.c.) e la Condotta delle Piattaforme

Quando un illecito online causa un danno, ci si interroga sulla responsabilità non solo dell'utente autore materiale, ma anche della piattaforma che lo ha ospitato. L'Art. 2055 c.c. stabilisce che se il fatto dannoso è imputabile a più persone, tutte sono obbligate in solido al risarcimento del danno.

Il danneggiato può quindi agire contro uno qualsiasi dei responsabili (spesso la piattaforma, in quanto "deep pocket", ovvero soggetto più solvibile). La responsabilità della piattaforma può scattare per diverse tipologie di condotta:

1. **Dolo:** Ha intenzionalmente lasciato il contenuto illecito online per trarne profitto.
2. **Colpa per Imprudenza:** Ha violato norme cautelari o regole del "non fare".
3. **Comportamento Omissivo:** Non si è attivata per rimuovere il contenuto *dopo* aver ricevuto una segnalazione qualificata (meccanismo di *Notice and Action*).

❗ Nel diritto penale e civile, c'è una profonda differenza tra la responsabilità per azione (causare attivamente un danno) e per omissione (non impedirlo). Affinché l'omissione sia rilevante, deve esistere a monte un *obbligo giuridico di impedire l'evento* (es. l'obbligo di rimozione che scatta per l'hosting provider dopo una segnalazione formale).

Nel regime di solidarietà, come accennato, il danneggiato ha il vantaggio di poter chiedere l'intero importo del risarcimento a un solo soggetto (es. la piattaforma).

Diritto di Rivalsa

Qualora la piattaforma sia costretta a risarcire l'intero danno causato primariamente dall'utente, esiste il Diritto di Rivalsa (o azione di regresso, ex Art. 2055 co. 2 c.c.): la piattaforma può agire legalmente contro l'utente colpevole per recuperare la quota di responsabilità a lui imputabile.

Nota metodologica

La lezione si è concentrata sull'esposizione di numerosi esempi pratici ed empirici per illustrare l'applicazione di queste dinamiche di responsabilità, che possono essere tutti ricondotti alla struttura teorica e normativa qui delineata.

Responsabilità Civile per Illecito Trattamento dei Dati Personali

Dinamiche del Processo Civile

In ambito civile, la richiesta di risarcimento del danno per un trattamento dei dati non adeguato segue regole procedurali rigorose. Il giudice valuta esclusivamente la fattispecie sottoposta alla

sua attenzione, non adottando una visione "ampia" ma limitandosi alla cornice dettata dalle parti.

Principio della domanda

Nel processo civile vige il principio della domanda (Art. 99 c.p.c.): l'autorità giudiziaria si pronuncia unicamente su quanto formalmente richiesto ed eccepito dai soggetti in causa.

All'interno di un processo civile si individuano le seguenti figure e componenti formali:

- **Attore:** colui che promuove l'azione in giudizio.
- **Convenuto:** il soggetto chiamato in giudizio a rispondere della pretesa dell'attore.
- **Chiamata in causa:** coinvolgimento di ulteriori soggetti terzi da parte del convenuto.
- **Petitem:** la domanda specifica rivolta al giudice (ciò che si chiede).
- **Causa petendi:** la spiegazione delle ragioni di fatto e di diritto che giustificano il petitem.

Petitem e causa petendi

La corretta individuazione di *petitem* e *causa petendi* è il pilastro su cui si incardina l'intero impianto accusatorio per la violazione dei dati personali.

L'Articolo 82 del GDPR: Diritto al Risarcimento

Art. 82 GDPR

"Chiunque subisca un danno materiale o immateriale a causa di una violazione del presente regolamento ha il diritto di ottenere il risarcimento del danno dal titolare del trattamento o dal responsabile del trattamento."

Info

Il termine "chiunque subisca" fa stretto riferimento alla figura dell'[interessato], che nel perimetro del GDPR è sempre e solo una **persona fisica**.

Applicando le logiche processuali a questa norma:

- **Attore:** chiunque subisca la lesione (l'interessato).

- **Petitem:** la richiesta di risarcimento. Questo include sia il danno immateriale (es. danno morale/sofferenza) sia il danno materiale, comprendente il **lucro cessante** (il mancato guadagno derivante direttamente dall'illecito).
- **Causa petendi:** la violazione oggettiva delle disposizioni del Regolamento.

La causa petendi

rappresenta il fondamento giuridico della domanda: senza l'allegazione e la dimostrazione delle ragioni fattuali dell'illecito, il petitem non può essere accolto.

Il danno lamentato deve essere provato in rapporto di causalità diretta con la violazione del GDPR.

Esempio pratico (Phishing)

In un attacco informatico andato a buon fine, i dati personali trattati in modo illecito o non protetti adeguatamente (es. nome utente e password sottratti) costituiscono la base materiale del danno su cui fondare la pretesa.

Esempi Pratici di Illecito e Danno

1. **Phishing Bancario:** L'utente cade nel tranello, ma può citare la banca (es. Poste Italiane) se dimostra che il sistema di sicurezza (solo nome utente e password) era inadeguato rispetto allo stato dell'arte (mancanza di **MFA/OTP**).
2. **SIM Swap:** Duplicazione fraudolenta della SIM. La banca può rispondere se ha basato la sicurezza esclusivamente sul possesso del numero telefonico, ignorando rischi prevedibili.
3. **Carta Revolving:** Carta recapitata al soggetto sbagliato (es. a un supermercato) e attivata da terzi. Il titolare risponde delle carenze identificative e organizzative.
4. **Omonimia vs Omocodia:** L'errore dell'Agenzia delle Entrate (due codici fiscali uguali) può esentare il titolare (banca) che si è fidato di registri ufficiali. La semplice omonimia (stesso nome) invece non giustifica l'invio a indirizzi errati senza controllo del CF.

Sicurezza e Responsabilizzazione (Accountability)

- **Art. 25 GDPR (Privacy by Design/Default):** La tutela deve essere incorporata nel sistema sin dalla progettazione. Il parametro è "mobile": bisogna aggiornarsi costantemente.
- **Art. 32 GDPR (Sicurezza del Trattamento):** Richiede misure adeguate allo "stato dell'arte" e al rischio. La sicurezza è un processo continuo, non un traguardo statico.
- **Vulnerabilità Zero-day:** Il titolare può liberarsi se prova che il danno deriva da un rischio non prevedibile e non evitabile con misure tecniche esigibili al momento del fatto (valutazione *ex ante*).

Il Titolare del Trattamento e Oneri Probatori

Il destinatario principale dell'azione (il convenuto) è tipicamente il **Titolare del trattamento**, ovvero colui che detiene il potere decisionale e stabilisce i mezzi e le finalità (i "modi") del trattamento. All'interno di un'organizzazione rappresenta un'entità unitaria, la quale può però demandare parte del trattamento a soggetti esterni (i cosiddetti Responsabili del trattamento).

Responsabile (Processor)

Risponde se va oltre le istruzioni del titolare o viola obblighi diretti del GDPR. Se decide autonomamente (es. usa dati per profilazione propria), diventa Titolare e "paga di tasca sua".

Onere della Prova

L'attore deve provare la violazione, il danno e il nesso causale. Tuttavia, il titolare può esonerarsi solo dimostrando che l'evento non gli è in alcun modo imputabile (Art. 82.3 GDPR).

Carico

La violazione a carico del Titolare deve essere rigorosamente dimostrata in corso di causa, quasi sempre mediante il supporto tecnico di una consulenza specializzata (CTU in ambito informatico).

Responsabilità Civile e Codici di Condotta

Art. 24 GDPR e Art. 20 D.Lgs. 101/2018

Il comportamento contrario ai codici di condotta di settore costituisce presupposto diretto per la responsabilità civile e fonda il diritto al risarcimento del danno.

Regole Deontologiche per l'Attività Giornalistica

Un ambito di forte scontro tra diritto alla riservatezza e altri diritti costituzionali (come la libertà di stampa) riguarda l'informazione giornalistica, soprattutto inerente alla salute.

Cassazione Civile, 21.06.2018, n. 16133

La Suprema Corte ha sanzionato l'illecita pubblicazione di notizie attinenti alla salute dell'interessato. Il caso riguardava un articolo di un quotidiano locale che esponeva nel dettaglio come due giovani fossero affetti dalla medesima sindrome che aveva già causato il decesso del fratello minore.

La pronuncia stabilisce un limite invalicabile: la divulgazione di notizie attinenti alla salute, in assenza del consenso dell'interessato, è consentita esclusivamente quando strettamente collegata all'essenzialità dell'informazione.

Info

Il bilanciamento tra il diritto di cronaca e la Data Protection impone il divieto di divulgazione di dettagli clinici esuberanti rispetto alla finalità puramente informativa della notizia.

Adeguatezza allo Stato dell'Arte

In chiusura, un principio cardine che permea tutto il diritto dell'informatica: le misure tecniche e organizzative adottate, così come le norme che le regolano, non sono concetti statici ma devono essere costantemente adeguate allo stato attuale della tecnica e dell'evoluzione tecnologica.

IA, Cybersecurity e Guerra Ibrida

IA nel Settore Militare e Guerra Ibrida

L'uso dell'IA in contesti bellici ("Guerra Ibrida") solleva questioni etiche e giuridiche fondamentali.

Guerra Ibrida: Forma di conflitto permanente che coinvolge infrastrutture, propaganda, cyberattacchi e manipolazione dei social. Eisenhower denunciò il rischio del **complesso militare-industriale-accademico**, dove università e ricerca sono intrecciate con la difesa.

Sistema Maven (Maven Smith System - Palantir)

Utilizzato dall'esercito americano per attacchi di precisione. Integra modelli come **Claude (Anthropic)** per aggregare enormi quantità di dati. La decisione finale spetta all'uomo, ma l'analisi è gestita da LLM.

Allineamento e Etica

L'**Allineamento (Alignment)** è l'obiettivo di progettare IA che non producano risultati pericolosi. Claude (Anthropic) usa la **Constitutional AI**: un sistema orientato da principi etici (una "costituzione" interna) ispirati ai diritti umani, ricordando le leggi della robotica di Asimov.

Definizione di Intelligenza Artificiale

Viene definita IA ogni simulazione tramite computer di processi mentali umani:

- Apprendimento e ragionamento.
- Risoluzione di problemi e percezione.
- Processi decisionali e linguaggio.

Storia ed Evoluzione Tecnica:

- **Hardware:** Negli anni '70/'80 dominavano i supercomputer **Cray**. Oggi la potenza di calcolo è spostata sulle **GPU (NVIDIA)**, nate per i videogiochi (calcolo parallelo) e rivelatesi ideali per l'addestramento delle reti neurali.
 - **Architetture:**
 - **Perceptron (1958):** Nato per fini militari (analisi foto aeree).
 - **Transformer (2017):** Base di tutti i LLM moderni (Google, *Attention Is All You Need*).
 - **GAN (Generative Adversarial Networks):** Un generatore sfida un discriminatore per creare immagini realistiche.
 - **AGI (Artificial General Intelligence):** Ad oggi non esiste; è l'obiettivo di un'IA indistinguibile dall'uomo ma scalabile.
-

Funzionamento dei Large Language Models (LLM)

Il "Peccato Originale": Architettura di Von Neumann

Il problema strutturale degli LLM (e dell'informatica moderna) risiede nell'**Architettura di Von Neumann**, dove **dati e codice condividono lo stesso spazio logico**. Non essendoci separazione assoluta, un dato (il nostro prompt) può essere interpretato come comando (**Prompt Injection**). Le soluzioni attuali (*Guard rails*) sono come "epicicli tolemaici": aggiustamenti complessi che non risolvono il problema strutturale.

I LLM non "ricordano" nel senso umano e non "ragionano", ma effettuano una pura **analisi statistica** (un "autocomplete" avanzato).

Architettura dell'Input

Non esiste una separazione netta tra codice e dati. L'input è composto da:

1. **System Prompt:** Istruzioni invisibili del produttore.

2. **Context Window:** La sequenza di prompt e output della sessione corrente (passata come input ad ogni turno).

Prompt Injection

Poiché ogni parte dell'input ha lo stesso valore, un input esterno può sovrascrivere il *System Prompt* o le istruzioni dell'utente. Questo è un rischio critico per gli Agenti AI che hanno accesso a dati privati.

Crittografia e "Crypto Wars"

La crittografia è stata a lungo considerata tecnologia strategica (assimilata ad armi). Negli anni '90, per aggirare le restrizioni USA all'esportazione di software cifrato (come **PGP**), il codice venne stampato su libri o magliette: la legge vietava l'export di bit, ma non della carta stampata (protetta dal Primo Emendamento).

I 6 Principi della Cybersecurity

La sicurezza dell'informazione si basa su una triade estesa (CIA+):

1. **Confidentiality (Riservatezza):** Solo chi è autorizzato legge i dati.
2. **Integrity (Integrità):** Impedire l'alterazione non autorizzata (*Tampering*).
3. **Availability (Disponibilità):** Il sistema deve essere accessibile (*Minaccia: DoS*).
4. **Authenticity (Autenticità):** Identificazione certa del mittente (*Minaccia: Spoofing*).
5. **Non-repudiability (Non-ripudiabilità):** Impossibilità di negare l'invio o la ricezione (concetto teorico legale).
6. **Authorization (Autorizzazione):** Livelli di accesso appropriati (*Minaccia: Elevation of privilege*).

Il Fattore Umano

PEBKC (*Problem Exists Between Keyboard and Chair*): L'anello debole è spesso l'utente (Social Engineering, Bad USB).

Beni, Contratti e Blockchain

I Beni e il Contratto

Secondo il Codice Civile:

- **Beni (Art. 810 c.c.):** Cose che possono formare oggetto di diritti.
- **Beni Immobili vs Mobili (Art. 812 c.c.):** Gli immobili sono saldamente al suolo; le energie sono equiparate ai beni mobili (Art. 814 c.c.).

Il Contratto (Art. 1321 c.c.)

L'accordo tra due o più parti per costituire, regolare o estinguere un rapporto giuridico patrimoniale.

Requisiti Essenziali (Art. 1325 c.c.):

1. Accordo delle parti.
2. Causa (funzione economico-sociale).
3. Oggetto (possibile, lecito, determinato).
4. Forma (se richiesta sotto pena di nullità).

Pay-or-Consent (Dati come controprestazione)

Il D.Lgs. 173/2021 riconosce che i **Dati Personali** possono essere una controprestazione patrimoniale. Il modello "Consenti o Paga" (es. Meta) è sotto esame dall'EDPB: il consenso deve essere libero e deve esistere un'alternativa equivalente.

Blockchain e Distributed Ledger Technology (DLT)

La blockchain nasce per risolvere il **Double Spending** senza intermediari centrali.

Caratteristiche Tecniche e Nodi

- **Decentralizzazione:** Modello **Peer-to-Peer** (opposto al client-server), dove ogni nodo può essere sia client che server.
- **Nodi Completi (Full Nodes):** Conservano e verificano l'intera blockchain.
- **Nodi Light:** Consultano le informazioni senza scaricare tutto il registro.
- **Immutabilità:** Garantita da **Hash** e **Proof-of-Work (PoW)**.
- **Nonce:** Numero variabile che i miner cambiano per trovare un hash valido (difficoltà).
- **Ambiente Trustless:** La fiducia è spostata dal soggetto umano al protocollo tecnico.

Meccanismi di Consenso

- **Proof-of-Work (PoW):** Basato sul lavoro computazionale (Mining, alto consumo energetico).
- **Proof-of-Stake (PoS):** Basato sulla partecipazione economica (asset vincolati).
- **Proof-of-Authority (PoA):** Validazione affidata a soggetti autorizzati (nodi identificati).

Tipologie di Blockchain

- **Pubblica (Permissionless):** Aperta a chiunque (es. Bitcoin). Verificabilità totale.
- **Privata (Permissioned):** Accessibile solo a soggetti autorizzati. Verificabilità limitata.
Nota: Blockchain e DLT (Distributed Ledger Technology) non sono sinonimi perfetti; la blockchain è una species del genus DLT.

Inquadramento Giuridico e Smart Contract

- **Validazione Temporale (Art. 8-ter d.l. 135/2018):** In Italia, la memorizzazione su DLT produce gli effetti giuridici della validazione temporale elettronica, utile per provare l'integrità e l'esistenza di un file a una certa data.
- **Smart Contract (Definizione):** Un programma per elaboratore la cui esecuzione vincola automaticamente le parti sulla base di effetti predefiniti.
- **La metafora del Distributore Automatico:** Lo smart contract è come una macchinetta del caffè; inserita la moneta e scelto il prodotto, l'esecuzione è automatica senza intervento umano.
- **Problemi Teorici:** Non sempre lo smart contract è un "contratto" civilistico. Può essere un mezzo di esecuzione di un accordo già concluso.
- **Forma Scritta:** La legge riconosce la forma scritta allo smart contract, ma solo previa **identificazione informatica** delle parti (requisiti AgID). Il codice da solo non prova il consenso valido, la causa o la liceità dell'oggetto.
- **Regolamento MiCA (2023/1114):** Disciplina le crypto-attività (ART, EMT, Utility Token) nell'UE.
- **DLT Pilot Regime:** Sperimentazione per strumenti finanziari tokenizzati.

Blockchain e GDPR

L'immutabilità della blockchain collide con il **Diritto alla Cancellazione** (Oblio). Le linee guida EDPB 2025 cercano di mediare tra architetture decentralizzate e responsabilità del titolare.

Protezione dei Dati e Nuove Frontiere Digitali

1. Data Bias

Definizione

Una distorsione sistematica e non casuale all'interno di un insieme di dati, che porta a una rappresentazione della realtà parziale, inaccurata o soggettiva. Nell'ambito dell'IA, il bias non è un errore statistico isolato, ma una proprietà strutturale del dataset o del modello.

1.1 Tipi di Data Bias

- **Bias di Algoritmo (Algorithmic Biases):** Pregiudizio insito nel codice o nei pesi assegnati.
 - **Caso Toeslagenaffaire (Olanda):** Algoritmo fiscale che discriminava le famiglie in base alla doppia cittadinanza.
 - **Caso SyRI (System Risk Indication):** Strumento di profilazione per frodi assistenziali, dichiarato illegittimo perché violava il bilanciamento tra efficienza amministrativa e privacy (Art. 8 CEDU).
- **Bias di Minoranza (Minority Bias):** Scarsa rappresentanza. Se il dataset riflette solo la maggioranza, il modello fallisce sulle "code" della distribuzione (outliers), marginalizzando ulteriormente gruppi già fragili.
- **Confirmation Bias (Bias di Conferma):** Tendenza a raccogliere dati che confermano preconcetti. Se un sistema di polizia predittiva viene addestrato su zone già storicamente più sorvegliate, genererà "profezie che si auto-avverano" (feedback loops).
- **Measurement Bias (Bias di Misurazione):** Errori negli strumenti o uso di variabili "proxy". Usare il CAP di residenza come parametro può essere un modo indiretto per discriminare in base al reddito o all'etnia (Redlining digitale).

1.2 Casi Studio e Impatto Giuridico

☐ Caso 1: Amazon Recruiting (2015)

- *Fatto:* Amazon creò un'IA per selezionare CV. Il modello, addestrato sui successi dell'ultimo decennio (prevalentemente maschili), imparò a penalizzare i CV che contenevano la parola "femminile".
- *Impatto sulla protezione dei dati:* Dimostra che la neutralità tecnologica è un mito. Viola il principio di **non discriminazione** e la necessità di controllo umano (Human-in-the-loop).

☐ Caso 2: COMPAS (Justitia)

- *Fatto:* Algoritmo USA per valutare il rischio di recidiva. Assegnava punteggi di rischio più alti ai neri rispetto ai bianchi a parità di reato.

- *Impatto sulla protezione dei dati:* Pone il problema dell'**opacità algoritmica** (Black Box). L'impossibilità di contestare la logica dietro una decisione lede il diritto alla difesa.

☐ **Caso 3: Algoritmo Grading A-Level (Regno Unito, 2020)**

- *Fatto:* Durante il COVID-19, un algoritmo ha assegnato i voti scolastici basandosi sulla "performance storica" degli istituti. Risultato: penalizzati gli studenti brillanti di scuole povere e favoriti quelli di scuole private d'élite.
- *Impatto:* Esempio di **bias socio-economico** istituzionalizzato. Il governo ha dovuto ritirare i voti dopo massicce proteste.

☐ **Caso 4: Algoritmo Optum/Impact Pro (Sanità USA)**

- *Fatto:* Algoritmo usato per identificare pazienti ad alto rischio che necessitavano di cure extra. Usava la "spesa sanitaria storica" come proxy del bisogno di salute. Poiché i neri spendevano storicamente meno (per minor accesso alle cure), venivano classificati come "meno malati" di bianchi con le stesse patologie.
- *Impatto:* **Proxy Bias**. L'uso di variabili economiche per decidere sulla salute crea discriminazioni sistemiche invisibili.

☐ **Caso 5: Apple Card / Goldman Sachs (Finanza)**

- *Fatto:* Segnalazioni di algoritmi di scoring del credito che assegnavano fidi molto più bassi alle donne rispetto ai mariti, pur con redditi e beni co-intestati identici.
- *Impatto:* Solleva il tema della **trasparenza algoritmica** nei servizi finanziari e della necessità di audit esterni.

☐ **Caso 6: Polizia Predittiva (PredPol / Geolitica)**

- *Fatto:* Software che suggeriscono alle pattuglie dove dirigersi basandosi su dati storici di arresti. Risultato: le pattuglie vengono mandate sempre nelle stesse zone, effettuano più arresti lì, alimentando il dataset in un circolo vizioso.
- *Impatto:* **Feedback Loop Bias**. Automatizza e "certifica" scientificamente pregiudizi storici di sorveglianza territoriale.

2. Dati Neurali (Neuro-dati)

La nuova frontiera della Privacy

I dati neurali raccolgono l'attività del sistema nervoso. A differenza dei dati personali "classici" (nome, posizione), i neuro-dati possono rivelare intenzioni, stati emotivi e pensieri prima ancora che vengano esteriorizzati.

2.1 Tipologie di Dati Raccolti

- **Tracciati EEG (Elettroencefalogramma):** Analisi delle frequenze cerebrali per rilevare stress, attenzione o gradimento (Neuromarketing).
- **BCI (Brain-Computer Interfaces):** Dispositivi (es. Neuralink) che permettono il controllo di macchine tramite il pensiero, ma che fungono anche da "canali di output" di dati intimi.
- **Dati Involontari:** Reazioni subconsce che l'utente non può controllare o mascherare, rendendo nullo il concetto tradizionale di "volontà" nel consenso.

2.2 Implicazioni Giuridiche ed Etiche: I Neuro-diritti

La sfida è l'aggiornamento del GDPR verso i **Neurorights**:

1. **Privacy Mentale:** Impedire l'accesso ai dati cerebrali senza consenso esplicito e consapevole.
2. **Identità Personale:** Proteggere l'integrità del "Sé" da interferenze esterne.
3. **Libero Arbitrio:** Garantire che le decisioni non siano manipolate da impulsi indotti tecnologicamente.

Il precedente del Cile

Il Cile è stato il primo paese al mondo (2021) a inserire in Costituzione la tutela dell'integrità mentale e dei dati cerebrali come diritti umani fondamentali.